

INTRODUCTION & IMPORTANCE OF SOC IN BLUE TEAM

23 June 2026 08:28

What is SOC (Security Operations Center)?

A Security Operations Center (SOC) is the heart of enterprise cyber defense. It helps organizations detect, investigate, and respond to threats – 24x7. Without a SOC, breaches go undetected, costing millions in damage, data loss, and reputation.

- **Protects** sensitive data and systems in real time
- **Reduces** breach costs by early detection & response
- **Complements** NOC (network uptime) and IR (post-breach response)

Why SOC exists?

Every day, organizations face thousands of cyber attacks—phishing emails, ransomware, data breaches, and insider threats. A single successful breach can cost millions in financial loss, legal penalties, and irreparable damage to reputation. The Security Operations Centre (SOC) exists as the first line of defence, monitoring networks 24x7 to detect, analyze, and respond to these threats before they cause catastrophic damage.

Real-world examples like the WannaCry ransomware attack (2017) affecting 200,000+ computers worldwide, or the Equifax breach exposing 147 million records, demonstrate why SOC vigilance matters. These weren't inevitable—proper SOC detection could have minimized impact significantly.

What is the role of SOC Analyst L1?

As a Tier-1 SOC Analyst, you are the first responder. You monitor, triage, escalate, and document every security alert.

- Monitor SIEM, EDR/XDR, firewall, email alerts
- Validate alerts: True Positive vs False Positive
- Escalate critical events to Tier-2/IR
- Log everything in ticketing systems

KPIs: Mean Time to Detect (MTTD), Response Time (MTTR), Accuracy, Escalation Quality

SOC vs NOC vs IR Team

1) SOC (Security Operations Center)

- **Focus:** Security monitoring and threat detection
- **Work:** Watches for cyber threats and suspicious activity
- **Activities:**
 - Monitors security alerts (24/7)
 - Detects malware, hacking attempts, data breaches
 - Analyzes and investigates alerts from security tools
- **Goal:** Identify security threats early

2) NOC (Network Operations Center)

- **Focus:** Network performance and availability
- **Work:** Keeps IT systems and network running smoothly
- **Activities:**
 - Monitors network uptime and speed
 - Checks bandwidth usage and connectivity issues
 - Fixes outages and performance problems
- **Goal:** Ensure systems and network stay online and stable

3) IR Team (Incident Response Team)

- **Focus:** Handling confirmed security incidents
- **Work:** Steps in when a real security breach is confirmed
- **Activities:**
 - Investigates security incidents in detail
 - Performs forensics (how attack happened, impact)
 - Contains and removes threats
 - Recovers systems after attack
- **Goal:** Minimize damage and restore security

☐ Think of SOC as the watchtower constantly scanning for enemies, NOC as maintaining the castle walls, and IR as the special forces deployed when attackers breach defences.

Daily Duties:

As a Junior Security Analyst, also called a SOC Level 1 Analyst, you work in a 24/7 SOC team and mostly review the security alerts together with your colleagues.

During your work shift, you would typically:

- Monitor and investigate various security alerts
- Participate in SOC brainstorms and workshops
- Cooperate with other teams to keep your company safe
- Constantly learn and discover new attacks and defenses

SOC Analyst L1 - Role (Frontline Security Monitoring)

1) Monitor & Triage Alerts (SIEM Monitoring)

- Continuously monitor **SIEM dashboards** (e.g., Splunk, QRadar, Sentinel)
- Review security alerts generated from:
 - IDS/IPS
 - Endpoint Detection (EDR)
 - Firewall logs
- Perform **initial triage**:
 - Is it a **True Positive (real threat)** or **False Positive (benign event)**?
- Collect basic context:
 - Source IP, destination IP
 - User account involved
 - Time of event
 - Alert severity

2) Analyze & Document (Log Investigation)

- Investigate using multiple logs:
 - Windows Event Logs (logon failures, privilege changes)
 - Firewall logs (blocked/allowed traffic)
 - Proxy/DNS logs (malicious domains, unusual requests)
- Identify **IOCs (Indicators of Compromise)**:
 - Suspicious IP addresses
 - Malware signatures
 - Unusual login patterns (e.g., brute force attempts)
- Document findings in ticketing tools (e.g., ServiceNow, Jira):
 - What happened
 - Evidence collected
 - Initial conclusion

3) Escalate or Close (Decision Making)

Decision based on analysis:

Close Case (False Positive):

- Normal user behavior
- Blocked benign activity (e.g., wrong password login attempt)

Escalate to L2/L3:

- Confirmed suspicious activity
- Multiple failed logins + successful login from foreign IP
- Malware detection or lateral movement signs

Example Scenario

Alert: "Multiple failed login attempts detected for user: admin from IP 185.23.x.x"

L1 SOC Actions:

1. Check SIEM dashboard

- Alert severity: Medium
- Source IP: External (unknown location)
- 2. Log Analysis**
 - Windows Event Logs show 20+ failed logins (Event ID 4625)
 - One successful login after failures (Event ID 4624)
 - GeoIP: Foreign country
- 3. IOC Identified**
 - Possible brute-force attack
 - Suspicious external IP
- 4. Decision**
 - ☒ Not a false positive
 - ☒ Escalate to L2 SOC / IR Team
- 5. Documentation**
 - "Possible brute-force attack detected on admin account. Multiple failed login attempts followed by successful login from foreign IP. Recommend account review and IP blocking."

Key Understanding

- **L1 = First filter (Noise → Signal)**
- Focus: Speed + Accuracy + Basic investigation
- Works in **24/7 shifts (SOC rotation model)**
- Acts as the **first line of defense in cybersecurity operations**

Attacker Scenario: Defender's Perspective

Understanding attacks from the SOC analyst viewpoint means focusing on detection, not exploitation. For each attack type, you need to know: what logs appear, which alerts fire, and your immediate response steps. Here are the most critical attack patterns you'll encounter on shift.

- 1. Phishing Attack**
 - a. **What SOC sees:** Email gateway alerts, user clicking suspicious link, outbound connection to newly registered domain.
 - b. **L1 action:** Check email headers, verify domain reputation, isolate user endpoint if compromise suspected.
- 2. Malware Execution**
 - a. **What SOC sees:** EDR alert on suspicious process, unsigned executable, outbound beacon to C2 server.
 - b. **L1 action:** Quarantine file, check VirusTotal hash, document IOCs, escalate for forensics.
- 3. Ransomware**
 - a. **What SOC sees:** Mass file encryption, ransom note creation, unusual disk activity, backup deletion attempts.
 - b. **L1 action:** Immediate escalation—time critical. Isolate affected systems, document timeline, notify IR team.
- 4. Brute Force**
 - a. **What SOC sees:** Multiple failed login attempts (Event ID 4625), account lockouts, login from unusual locations.
 - b. **L1 action:** Verify legitimate user activity, block source IP, check for successful compromise, reset credentials if needed

Alert Triage - SOC Decision-Making Framework (L1 Analyst)

Alert triage is the **process of quickly analyzing security alerts from SIEM/EDR and deciding whether to close or escalate**. The goal is to reduce noise and identify real threats fast.

1. Initial Assessment (Context Understanding)

- Read the **alert title and description**
- Check **severity level (Low / Medium / High / Critical)**
- Identify the **affected asset**:
 - Server (high risk)
 - User endpoint (medium risk)
- Check **timing**:
 - Business hours vs unusual time (e.g., 2-4 AM increases suspicion)

Key Questions:

- What system is affected?
- Who is affected (user/server)?
- How serious is the alert?

2. Log Analysis (Technical Investigation)

Use SIEM tools (Splunk, QRadar, Sentinel) to pull related logs.

Check time window:

- 30 minutes before and after alert

Analyze:

- Source IP / Destination IP
- User account involved
- Process name (e.g., powershell.exe, cmd.exe)
- Event frequency (single vs repeated activity)

Example Log Data:

- Event ID 4625 → failed login
- Event ID 4624 → successful login
- Firewall log → outbound connection
- EDR log → suspicious process execution

3. Context Gathering (Threat Validation)

This step determines if activity is **legitimate or malicious**.

Checks:

- Is **source IP internal or external**?
- Is the **user account valid and active**?
- Does threat intelligence flag the IP/domain?
 - Known malicious IP?
 - Phishing domain?
- Have similar alerts occurred recently?

Tools used:

- Threat Intelligence feeds (VirusTotal, AlienVault OTX)
- Internal asset inventory
- Active Directory validation

4. Decision Making

Based on analysis, choose one:

☒ True Positive → Escalate

- Confirmed suspicious or malicious activity
- Create incident ticket
- Escalate to **L2 SOC / IR Team**

☒ False Positive → Close

- Benign or expected behavior
- Misconfigured rule or normal admin activity
- Close ticket with justification

☒ Unsure → Escalate

- If doubt exists → escalate immediately
- Principle: **"Better escalate than miss a breach"**

True Positive Indicators (High Confidence Threats)

These patterns strongly suggest real attacks:

- Connection to **known malicious IP/domain**
- Access at unusual time (e.g., **3 AM login to finance server**)
- Privilege escalation attempts (user → admin)
- Data exfiltration (large uploads to cloud, FTP, external IP)
- Brute force attack pattern:
 - Multiple failed logins → successful login
- Suspicious PowerShell / encoded commands execution

Common False Positives

These are safe events often flagged incorrectly:

- Vulnerability scans (Nessus, Qualys) detected as port scans
- Admin performing legitimate maintenance
- SIEM rule misconfiguration (low threshold alerts)
- Antivirus/EDR heuristics on trusted software
- Scheduled tasks appearing as unknown processes

Example Scenario (Technical Case)

Alert: "Multiple failed login attempts followed by successful login for user: admin from external IP 185.45.x.x"

1. Initial Assessment

- Severity: High
- Asset: Domain Controller (critical system)
- Time: 2:30 AM (unusual)

2. Log Analysis

- Event ID 4625 → 25 failed login attempts
- Event ID 4624 → successful login
- Source IP: External (unknown)
- Login method: Remote RDP

3. Context Gathering

- IP not found in whitelist
- Threat intelligence → flagged as suspicious
- User "admin" usually logs in from internal network only

4. Decision

- ✓ True Positive (Brute Force Attack)
- Action:
 - Escalate to L2 SOC / IR Team
 - Block IP at firewall
 - Force password reset for account

Summary (Quick Revision)

- **Step 1:** Understand alert context (what, who, when)
- **Step 2:** Analyze logs (SIEM investigation)
- **Step 3:** Validate threat (IP, user, TI feeds)
- **Step 4:** Decide (Close / Escalate / Unsure → Escalate)

Core Idea:

🔗 SOC L1 = "Filter Noise → Detect Real Threats → Escalate Correctly"

Interview Mastery: Technical & Scenario Questions

SOC interviews test both knowledge and thinking process. Interviewers want to see how you approach problems under pressure, not just memorized definitions. Practice these common questions with structured, professional responses that demonstrate real SOC experience.

Question: "You receive an alert for 50 failed login attempts. What do you do?"

Poor answer: "I'd escalate it."

Strong answer: "First, I'd check the timeframe—50 attempts in 1 minute suggests automated brute force, whilst 50 over 24 hours might be a legitimate user with password issues. I'd verify the source IP—is it internal or external? Check reputation. Review if any attempts succeeded. Check for similar activity against other accounts. If it's external automated attack, I'd block the IP and document IOCs. If internal, I'd contact the user to verify. Only escalate if I see successful compromise indicators like unusual post-login activity."

Question: "Explain the difference between IDS and IPS."

Poor answer: "IDS detects, IPS prevents."

Strong answer: "IDS (Intrusion Detection System) passively monitors network traffic and alerts on suspicious activity but doesn't block it—like a CCTV camera recording events. IPS (Intrusion Prevention System) actively blocks malicious traffic in real-time—like a security guard stopping intruders. In SOC context, IDS generates alerts we analyze, whilst IPS automatically prevents known threats. Trade-off: IPS can cause false positive blocks affecting business, so we carefully tune rules."

Question: "A user reports their account is locked. How do you investigate?"

Strong answer: "I'd query SIEM for Event ID 4740 (account lockout) and 4625 (failed logins) for that username. Check: How many failed attempts? From which IP addresses? Are they internal or external? Timing pattern—rapid attempts suggest brute force, sporadic might be user error. Check if the user was actually trying to log in—call or email to verify. Review any successful logins from unusual locations. If it's a compromise attempt, I'd reset credentials, check for any successful access, and escalate for deeper investigation of potential lateral movement."

HUMAN ATTACK VECTORS, PROCESS & TECHNOLOGY

25 June 2026 10:54

As a Tier-1 SOC Analyst, you are the first responder. You monitor, triage, escalate, and document every security alert.

- Monitor SIEM, EDR/XDR, firewall, email alerts
- Validate alerts: True Positive vs False Positive
- Escalate critical events to Tier-2/IR
- Log everything in ticketing systems

Core Concept

The main focus of the SOC team is to keep **Detection and Response** intact

People, Process, and Technology coexist in a SOC environment. A team of professional individuals working on state-of-the-art security tools in the presence of proper processes is what makes a mature SOC environment.



PEOPLE

- **SOC Analyst (Level 1):** Anything detected by the security solution would pass through these analysts first. These are the first responders to any detection. SOC Level 1 Analysts perform basic alert triage to determine if a specific detection is harmful. They also report these detections through proper channels.
- **SOC Analyst (Level 2):** While Level 1 does the first-level analysis, some detections may require deeper investigation. Level 2 Analysts help them dive deeper into the investigations and correlate the data from multiple data sources to perform a proper analysis.
- **SOC Analyst (Level 3):** Level 3 Analysts are experienced professionals who proactively look for any threat indicators and support in the incident response activities. The critical severity detection reported by Level 1 and Level 2 Analysts are often security incidents that need detailed responses, including containment, eradication, and recovery. This is where Level 3 analysts' experience comes in handy.
- **Security Engineer:** All analysts work on security solutions. These solutions need deployment and configuration. Security Engineers deploy and configure these security solutions to ensure their smooth operation.
- **Detection Engineer:** Security rules are the logic built behind security solutions to detect harmful activities. Level 2 and 3 Analysts often create these rules, while the SOC team can sometimes also utilize the detection engineer role independently for this responsibility.
- **SOC Manager:** The SOC Manager manages the processes the SOC team follows and provides support. The SOC Manager also remains in contact with the organization's CISO (Chief Information Security Officer) to provide him with updates on the SOC team's current security posture and efforts.

PROCESS



1. ALERT TRIAGE

The alert triage is the basis of the SOC team. The first response to any alert is to perform the triage

Alert: Malware detected on Host: GEORGE PC

5 Ws Answers

What?

A malicious file was detected on one of the hosts inside the organization's network.

When?

The file was detected at 13:20 on June 5, 2024.

Where?

The file was detected in the directory of the host: "GEORGE PC".

Who?

The file was detected for the user George.

Why?

After the investigation, it was found that the file was downloaded from a pirated software-selling website. The investigation with the user revealed that they downloaded the file as they wanted to use a software for free.

2. REPORTING

The detected harmful alerts need to be escalated to higher-level analysts for a timely response and resolution. These alerts are escalated as tickets and assigned to the relevant people. The report should discuss all the 5 Ws along with a thorough analysis, and screenshots should be used as evidence of the activity.

3. INCIDENT RESPONSE AND FORENSICS

Sometimes, the reported detections point to highly malicious activities that are critical. In these scenarios, high-level teams initiate an incident response.

A few times, a detailed forensics activity also needs to be performed. This forensic activity aims to determine the incident's root cause.

TECHNOLOGY

Having the right People and Processes in place would never be enough without security solutions for detection and response. The Technology portion in the SOC pillars refers to the security solutions. These security solutions efficiently minimize the SOC team's manual effort to detect and respond to threats.

1. **SIEM:** Security Information and Event Management (SIEM) is a popular tool used in almost every SOC environment. This tool collects logs from various network devices, referred to as log sources.

Detection rules are configured in the SIEM solution, which contains logic to identify suspicious activity. The SIEM solution provides us with the detections after correlating them with multiple log sources and alerts us in case of a match with any of the rules.

Modern SIEM solutions surpass this rule based detection analysis, providing us with user behavior analytics and threat intelligence capability. Machine learning algorithms support this to enhance the detection capabilities.

Note: The SIEM solution only provides the Detection capabilities in a SOC environment.

2. **EDR:** Endpoint Detection and Response (EDR) provides the SOC team with detailed real-time and historical visibility of the devices' activities. It operates on the endpoint level and can carry out automated responses. EDR has extensive detection capabilities for endpoints, allowing you to investigate them in detail and respond with a few clicks.
3. **Firewall:** A firewall functions purely for network security and acts as a barrier between your internal and external networks (such as the Internet). It monitors incoming and outgoing network traffic and filters any unauthorized traffic. The firewall also has some detection rules deployed, which help us identify and block suspicious traffic before it reaches the internal network.

Several other security solutions play unique roles in a SOC environment, such as Antivirus, EPP (Endpoint Protection Platform), IDS/IPS, XDR (Extended Detection and Response), SOAR (Security Orchestration, Automation, and Response), and more. The decision on what Technology to deploy in the SOC comes after careful consideration of the threat surface and the available resources in the organization.

SECURITY DEPARTMENTS

In tiny companies, the IT department takes the role of securing the company. Small to medium-sized companies may have a generic "Information Security" team that does all sorts of tasks. Bigger companies have a CISO overseeing multiple security teams, each handling a specific task.

- **Red Team:** Offensive security experts, pentesters, or ethical hackers who look for security issues
- **GRC Team:** Specialists managing policies and ensuring compliance with regulations like [PCI DSS](#)
- **Blue Team:** Defensive security experts like [SOC](#) analysts, engineers, or incident responders
- **L1 Analysts:** Junior members who triage alerts and pass complex cases to L2
- **L2 Analysts:** Experienced members who investigate more advanced attacks
- **Engineers:** Experts in configuring security tools like [EDR](#) or [SIEM](#)
- **Manager:** A person who manages the whole [SOC](#) team

If SOC expertise is not enough or the incident goes out of control, you urgently call the "firefighters" - CIRT (Cyber Incident Response Team), also called CSIRT or CERT. The members should have a broad knowledge of cyber threats and handle breaches without depending on tools like EDR or SIEM.

HUMAN ATTACK VECTORS IN SOC

Not every organization has the expertise to operate a SOC on its own and relies on a Managed Security Services Provider (MSSP), a company that

delivers outsourced security services, most commonly SOC, to its clients. Working at MSSP is typically high-pressure, but it is also a good option to quickstart your career.

Why Humans Are Targeted

Humans are targeted because of the access they can provide - to websites, mailboxes, or databases. Some threat actors hunt for a specific access, while others are not so selective and just breach as many accounts as they can and decide how to use them later

Attacks targeting humans share a common trait: they rely on manipulating the victim into helping the attacker, whether knowingly or not. This tactic is known as **social engineering**, and it works by exploiting human psychology rather than technical flaws. For the tactic to succeed, it is designed to be:

Trustworthy: The attacker must appear legitimate so the victim trusts them

Emotional: The attack must trigger feelings like urgency, fear, or curiosity

- Phishing Attacks
- Malware Downloads
- Deep Fakes
- Impersonation
- Other Attacks like Keylogging, Physical attacks etc

HOW TO DEFEND HUMANS

Defending against threats involves two key tasks: **Mitigation and Detection**. Mitigation aims to prevent or reduce the chance and impact of attacks, for example by training employees or deploying a good anti-phishing solution.

HOW TO DEFEND HUMANS

As a SOC analyst, your task is to detect and investigate attacks, because after sometime you will be tired of manual mitigation & will want automated way and there comes the SOC suite of automated solutions. Some solutions are :

- Anti-phishing solution
- Antivirus / EDR solution
- "Trust but verify" principle
- Security awareness training

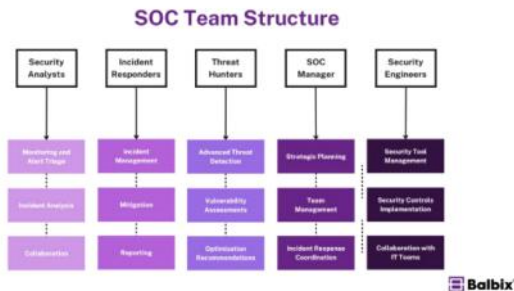
SYSTEM ATTACK VECTORS & VULNERABILITY

25 June 2026 11:44

The 3 SOC Operating Models

1. In-House (Internal) Soc

A company builds and runs its own SOC internally using its own people, tools, and processes.



2. Outsourced / Managed SOC (MSP/ MSSP SOC) - A third-party security company (MSSP) provides SOC services to multiple client organizations.

MSP : Managed Service Providers

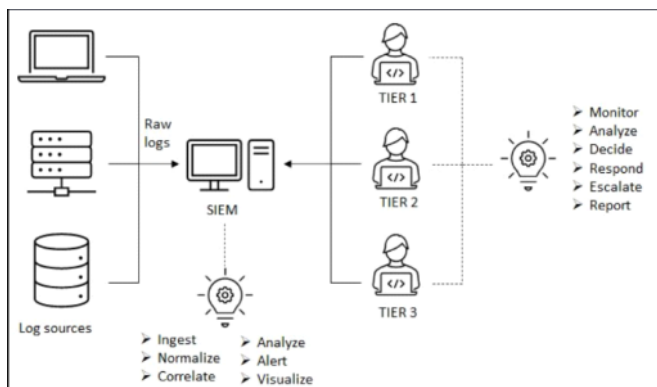
MSSP : Managed Security Service Providers



3. Hybrid SOC (Co-Managed SOC) - A shared responsibility model b/w -

a. Internal SOC team AND

b. External MSSP



System As Attack Vector

If you understand systems as attack vectors, you stop being a beginner and start thinking like an analyst. In SOC, we don't just protect users or data, we protect SYSTEMS, because every system

can be abused as an attack vector.

A system becomes an attack vector when an attacker uses it to:

1. Gain initial access

Meaning: First entry into the system.

Example: An attacker uses a phishing email to steal employee login credentials and access a company portal.

2. Move laterally

Meaning: Spreading from one system to others inside the network.

Example: After compromising one employee laptop, the attacker uses stolen credentials to access a file server.

3. Maintain persistence

Meaning: Staying inside the system even after reboots or password changes.

Example: Installing a backdoor or scheduled task that reconnects the attacker to the system.

4. Exfiltrate data

Meaning: Stealing and sending data out of the organization.

Example: Compressing customer database files and sending them to an external cloud storage or attacker server.

5. Launch further attacks

Meaning: Using the compromised system to attack other targets.

Example: Using the infected machine to send malware emails to other companies or perform DDoS attacks.

Human Oriented Attacks

Users are those who start the attack mostly : (Before external factors, Users are responsible at first)

By inserting a malicious USB found on a street, downloading malware from pirated resources, or simply reusing a weak password everywhere. 81% of breaches involve stolen or breached passwords.

Example:

● Rubber Ducky

Meaning: A USB device that looks normal but injects malicious keystrokes when plugged in.

Example: Plugging in a "USB drive" that automatically opens a command prompt and installs malware.

● Keyloggers binded with legitimate software

Meaning: Hidden keylogging malware packaged inside trusted-looking applications.

Example: Downloading a "free PDF tool" that secretly records everything you type, including passwords.

● Clicking on suspicious links

Meaning: Opening malicious URLs that lead to phishing or malware sites.

Example: Clicking a "bank alert" link that leads to a fake login page stealing credentials.

● Opening any email or sent attachments

Meaning: Executing harmful files or scripts delivered via email.

Example: Opening an invoice attachment that installs ransomware on the system.

● Storing passwords on unsecure portals

Meaning: Saving credentials in unsafe websites or apps without encryption or security.

Example: Saving passwords in a random online note-taking site that gets hacked.

● Trusting too quickly

Meaning: Falling for social engineering due to lack of verification.

Example: Sharing OTP or login details with someone pretending to be IT support.

● Using outdated/pirated software

Meaning: Running unpatched or cracked software with known vulnerabilities.

Example: Using a pirated OS that contains hidden malware or exploitable security flaws.

Supply Chain Attacks

A supply chain attack is when an attacker doesn't directly target the main organization, but instead compromises a trusted third party (supplier, vendor, software provider, or update system) to reach the real target.

Your PC is home to hundreds of apps, including web browsers, messengers, development, and entertainment software. Every app depends on thousands of libraries.

If threat actors manage to breach one of the apps or libraries and push an update to all its users, all of them will be compromised. This technique is called a supply chain attack. The most famous examples are the SolarWinds and 3CX breaches which affected thousands of companies.

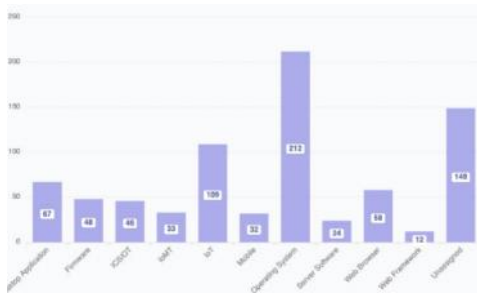
It is hard to protect from supply chain attacks since you can't always control all the software present on your laptops, servers, and web apps.

It becomes a supply chain attack when the compromise happens through something the victim trusts and depends on, such as:

- Software updates
- Third-party vendors
- Libraries or code dependencies
- Hardware or firmware
- Managed service providers

Vulnerabilities

Every piece of software have security flaws. In 2024, over 40,000 software vulnerabilities were published and more than 300 were actively exploited in major attacks.



The vulnerabilities added by CISA to its catalog in 2022 impacted a wide range of products, but operating systems and IoT accounted for the highest percentages.

A vulnerability is a weakness in a system, software, hardware, or process that can be exploited by an attacker to Gain access, Escalate privileges, Execute code. Steal data, Disrupt services & more...

"A vulnerability is a flaw or weakness in a system that can be exploited to compromise confidentiality, integrity, or availability."

Vulnerabilities can exist in Softwares, OS, Applications, Network Devices, Firmwares, Cloud Services or even Security Software solutions

Software Vulnerabilities

Every piece of software has flaws, but some take years to be discovered. For example, Shellshock,

a major Linux vulnerability, existed since 1992 but wasn't found until 2014. In the worst-case scenario, attackers discover the vulnerability before anyone else. This is known as a zero-day, and only your SOC skills can determine whether it gets detected in time.

Once a vulnerability is made public, it is assigned a Common Vulnerabilities and Exposures (CVE) number. From that moment, it's a race: attackers develop exploits while defenders rush to update their systems.

An answer to a CVE is always a patch - an update supplied by the software vendor. Even for zero-days, you'll have to wait for a patch, vigilantly monitor for exploitation traces, and try to survive the stressful period before the patch is released. For example, by:

- Restricting access to the system to only trusted IPs
- Applying temporary measures provided by the vendor
- Blocking known attack patterns on IPS or WAF

● SQL Injection

Meaning: Attacker injects malicious SQL queries to manipulate a database.

Example: Entering ' OR '1'='1 in a login form to bypass authentication.

SOC Detection:

WAF alerts for SQL patterns (OR 1=1, '--)
Database error logs
Unusual query spikes in web logs

● Command Injection

Meaning: Attacker executes system commands through a vulnerable application.

Example: Input like ; rm -rf / in a web form that gets executed on the server.

SOC Detection:

Web server logs showing command-like input (;, &&, |)
EDR alerts on suspicious shell execution
Unexpected process creation (cmd/bash)

● Buffer Overflow

Meaning: Sending more data than a program can handle, causing memory corruption and possible code execution.

Example: Sending an oversized input string to crash a vulnerable application.

SOC Detection:

Application crashes or segmentation faults
EDR alerts for abnormal memory access
Unexpected process termination/restarts

● Cross-Site Scripting (XSS)

Meaning: Injecting malicious scripts into web pages viewed by other users.

Example: Posting <script>stealCookies()</script> in a comment section.

SOC Detection:

WAF alerts for script tags or JavaScript payloads
Web logs showing encoded payloads
Unusual client-side activity (session hijacking attempts)

● Remote Code Execution (RCE)

Meaning: Attacker runs arbitrary code on a remote system.

Example: Exploiting a vulnerable web app to execute whoami or install malware.

SOC Detection:

EDR alerts for unauthorized process execution
Web server logs showing exploit attempts
Sudden outbound connections from server (C2 traffic)

● Windows Vulnerabilities

Meaning: Weaknesses in Windows OS services, components, or configurations that attackers exploit.

Example: Exploiting SMB vulnerability like EternalBlue to spread ransomware across networks.

SOC Detection:

SMB traffic spikes (port 445 scanning)

EDR alerts for exploit behavior (e.g., WannaCry-like activity)

Unexpected lateral movement between systems

● Linux Vulnerabilities

Meaning: Security flaws in Linux kernel, services, or permissions.

Example: Exploiting misconfigured sudo permissions to gain root access.

SOC Detection:

Sudden privilege escalation to root

Suspicious sudo command usage in logs

Unauthorized process execution with root privileges

● macOS Kernel or Service Vulnerabilities

Meaning: Weaknesses in macOS system kernel or system services.

Example: Exploiting a kernel bug to bypass security protections and install spyware.

SOC Detection:

Kernel panic or unusual system crashes

EDR alerts for unauthorized system-level changes

Suspicious system service modifications

● Privilege Escalation Bugs

Meaning: Exploiting flaws to gain higher access rights than intended.

Example: A normal user exploiting a bug to become admin/root.

SOC Detection:

Sudden role/permission changes

Unauthorized admin group additions

Abnormal login session behavior

● SMB Vulnerabilities (e.g., EternalBlue)

Meaning: Exploiting Microsoft SMB protocol flaws for remote compromise and propagation.

Example: WannaCry ransomware spreading across networks using SMB exploit.

SOC Detection:

High volume of SMB connection attempts (port 445)

Lateral movement between hosts

Ransomware execution alerts in EDR

● Kernel Exploits

Meaning: Attacks targeting OS kernel to gain full system control.

Example: Exploiting kernel vulnerability to disable antivirus or gain SYSTEM/root access.

SOC Detection:

Kernel driver loading without authorization

EDR alerts for system-level privilege abuse

Security tool tampering or disabling

Network Vulnerabilities

● Open Ports

Meaning: Unnecessary network ports left accessible, allowing attackers to probe or exploit services.

Example: Port 23 (Telnet) or 3389 (RDP) exposed to the internet.

SOC Detection:

Port scanning alerts from IDS/IPS
Firewall logs showing repeated connection attempts
Unusual inbound traffic patterns
● Weak Protocols (Telnet, FTP, HTTP)

Meaning: Using insecure communication protocols that send data in plain text.
Example: Logging into a server using Telnet, exposing usernames and passwords.

SOC Detection:

Detection of unencrypted traffic (cleartext credentials)
IDS alerts for legacy protocol usage
Network monitoring flags for insecure sessions
● Unpatched Routers / Firewalls

Meaning: Network devices running outdated firmware with known vulnerabilities.
Example: Exploiting a router firmware bug to gain admin access.

SOC Detection:

Vulnerability scanner alerts
Unexpected configuration changes
Traffic rerouting or DNS changes detected
● Exposed Admin Interfaces

Meaning: Administrative panels accessible from public networks without restriction.
Example: A firewall or router login page accessible via the internet.

SOC Detection:

Web logs showing repeated login attempts
IDS alerts for admin panel access attempts
Brute-force detection on login pages
● Excessive Authentication Failures

Meaning: Repeated failed login attempts indicating brute-force attacks.
Example: Thousands of login attempts on VPN or SSH.

SOC Detection:

Firewall/SSO logs showing repeated failures
Account lockout events
IDS brute-force attack alerts

Authentication & Authorization Vulnerabilities

● Weak Passwords

Meaning: Easy-to-guess passwords that attackers can crack or brute-force.
Example: Using passwords like 123456, admin@123, or company name-based passwords.

SOC Detection:

Multiple failed login attempts (brute-force alerts)
Account lockout events
Login attempts from unusual IPs or locations
● No MFA (Multi-Factor Authentication)

Meaning: Accounts protected only by password, without an extra verification layer.
Example: Logging into email or VPN using only a password.

SOC Detection:

Successful logins from new devices without MFA prompts
Suspicious login sessions from unfamiliar locations
IAM alerts for high-risk sign-ins
● Broken Access Control

Meaning: Users can access data or functions they are not authorized to.
Example: A normal user accessing admin panel by changing URL like /admin/dashboard.

SOC Detection:

Access logs showing unauthorized resource access attempts
WAF alerts for privilege bypass patterns
Repeated 403/200 mismatches (access anomalies)

● Privilege Escalation Paths

Meaning: Exploiting flaws to gain higher privileges than assigned.
Example: A user exploiting misconfigured roles to become admin.

SOC Detection:

Sudden role changes in IAM logs
Unauthorized group membership updates
EDR alerts for privilege escalation behavior

Configuration-Dependent Vulnerabilities

● Debug Mode Enabled

Meaning: Applications left in development/debug mode expose sensitive information and internal details.

Example: A web app showing full error stack traces or database queries to users.

SOC Detection:

Web logs showing error/debug endpoints (e.g., /debug, /test)
Exposure of sensitive error messages in responses
WAF alerts for debug parameter access

● Default Credentials

Meaning: Systems still using factory-set usernames and passwords.
Example: Router login using admin/admin or admin/password.

SOC Detection:

Successful login attempts using common default credentials
Repeated login attempts from known credential lists
IAM or device logs showing unchanged initial accounts

● Excessive Permissions

Meaning: Users or services given more access than required (over-privileged accounts).
Example: A normal employee account having admin access to all servers.

SOC Detection:

IAM alerts for privilege misuse
Unusual access to restricted resources
Audit logs showing access outside user role scope

Zero-Day vulnerability

Meaning: A security flaw that is unknown to the software vendor and has no patch available, so attackers exploit it before it is fixed.

Example: Hackers exploit a newly discovered flaw in a browser or operating system to install malware before any update is released.

SOC Detection:

● Abnormal processes

Unexpected or unknown programs running on endpoints that should not normally execute.
Example: A legitimate application suddenly spawning PowerShell or cmd.exe.

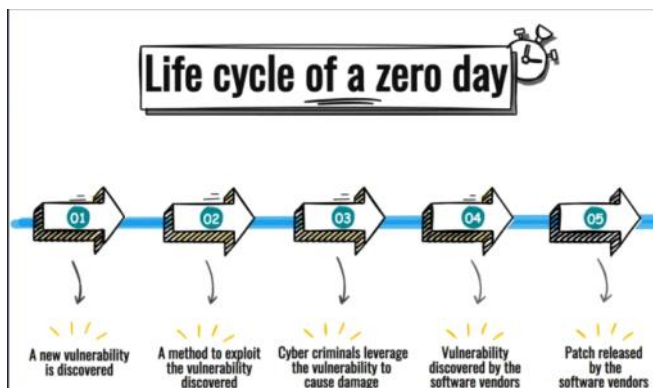
- Suspicious network traffic

Unusual outbound connections or communication with unknown command-and-control (C2) servers.
Example: A workstation repeatedly sending encrypted data to an unknown IP address.

- Lateral movement

Attack spreading from one system to another inside the network after initial compromise.
Example: One infected laptop accessing multiple servers using stolen credentials.

Term	Meaning
Vulnerability	Weakness exists
Exploit	Vulnerability is abused
Incident	Damage or compromise occurs



Common Misconfigurations For SOC: Cloud Misconfigurations

- Public S3 Buckets

Meaning: Cloud storage (like AWS S3) is accidentally made publicly accessible.
Example: A company stores customer data in an S3 bucket, but anyone on the internet can access it.

SOC Detection:

Cloud security alerts (AWS Config / CSPM tools)
Public access flag enabled in storage logs
Unusual external downloads from storage

- Open Azure Blob Storage

Meaning: Azure storage containers are exposed without proper authentication.
Example: A blob container with sensitive files accessible via a public URL.

SOC Detection:

Azure Defender alerts
Anonymous access logs to storage
High volume of external data downloads

- Over-permissive IAM Roles

Meaning: Users or services are given more cloud permissions than required.
Example: A developer account with full admin access to all cloud resources.

SOC Detection:

IAM policy violation alerts
Unusual access to sensitive cloud services
Privilege escalation activity in audit logs

● Exposed Access Keys

Meaning: Cloud API keys or secrets are accidentally leaked or stored insecurely.
Example: AWS access key uploaded to GitHub repository.

SOC Detection:

CloudTrail alerts for unusual API usage
Detection of leaked keys in public repositories
Login attempts from unusual IP addresses using keys
Attack Flow Example

S3 bucket public

↓

Sensitive data indexed by search engines

↓

Unauthorized access / data breach

SOC Example Insight (Key Idea)

Misconfiguration is not a software bug, but a setup or human error in system configuration.

Example cause:

Using weak/default settings (like simple passwords)
Enabling public access for convenience
Giving excessive permissions to avoid access issues

Network Misconfigurations

● Firewall Allows ALL Traffic

Meaning: Firewall rules are too open, allowing unrestricted inbound/outbound traffic.
Example: A firewall rule set to "allow any-any" exposing all services to the internet.

SOC Detection:

Firewall logs showing high volume of allowed traffic
IDS/IPS alerts for broad scanning activity
Unexpected external connections to multiple ports

● Internal Services Exposed Externally

Meaning: Internal-only systems are mistakenly accessible from the internet.
Example: A database or internal API is reachable publicly without restriction.

SOC Detection:

External port scanning alerts (Nmap-like activity)
Cloud security exposure alerts
Unexpected inbound connections to internal IP ranges

● No Network Segmentation

Meaning: Entire network is flat, with no separation between users, servers, and critical systems.
Example: Employee laptops can directly access production database servers.

SOC Detection:

Lateral movement detected via EDR
Excessive internal traffic between unrelated systems
Same credentials used across multiple systems
Attack Flow Example

Internal DB port exposed

↓

External attacker scans and finds open port

↓

Unauthorized database access

Identity Misconfigurations

● MFA Disabled for Admins

Meaning: Privileged accounts are not protected with multi-factor authentication, making them easier to compromise.

Example: An attacker logs into a cloud admin account using only a stolen password.

SOC Detection:

IAM alerts showing high-risk admin logins without MFA

Login from unusual location/device

Impossible travel or suspicious sign-in patterns

● Excessive Group Memberships

Meaning: Users are added to too many groups, giving them unnecessary permissions.

Example: A normal employee is part of both HR and IT admin groups.

SOC Detection:

IAM policy violation alerts

Access to resources outside user role

Audit logs showing unusual permission scope

● Shared Admin Accounts

Meaning: Multiple people use the same admin credentials, making tracking and accountability difficult.

Example: Several IT staff using a single "admin" login for server management.

SOC Detection:

Multiple logins from different IPs/devices using same account

Simultaneous sessions from different locations

Inability to map actions to a single user

Attack Flow Example

Compromised user account

↓

Account already has admin privileges

↓

No need for privilege escalation → full system access immediately

Endpoint Configurations

● Antivirus Disabled

Meaning: Endpoint protection software is turned off or not functioning, leaving systems unprotected.

Example: A user disables antivirus to install pirated software, allowing malware to run freely.

SOC Detection:

EDR/AV service shutdown alerts

Missing security agent reports

Sudden drop in endpoint protection coverage

● Local Admin Access

Meaning: Users are given administrator rights on their own machines unnecessarily.

Example: An employee installs unauthorized software or malware using admin privileges.

SOC Detection:

Privilege escalation logs on endpoints
Unapproved software installation alerts (EDR)
Audit logs showing admin group membership changes
● USB Allowed Everywhere

Meaning: USB storage devices are permitted without restriction, increasing malware risk.
Example: An infected USB drive introduces ransomware into a workstation.

SOC Detection:

USB device insertion logs (EDR/endpoint monitoring)
Detection of unknown executables from removable media
Malware execution alerts from external drives
Attack Flow Example

Malware executed on endpoint

↓

No antivirus/EDR protection

↓

Persistence established (startup scripts, registry keys, scheduled tasks)

SOC Key Insight

Most real-world breaches happen due to:

- ☞ Poor configuration
- ☞ Weak endpoint security
- ☞ Lack of monitoring

Not advanced zero-day exploits.

SOC Example Statement (Concept)

"Most breaches don't happen because of zero-days, they happen because of misconfigurations and unpatched vulnerabilities."

Major System Categories Used as Attack Vectors



Endpoints:

- What are Endpoints?

Meaning: Endpoints are end-user devices or computing machines that connect to a network.

Examples:

Laptops
Desktops
VDI (Virtual Desktop Infrastructure)
Workstations

- How attackers use endpoints

Endpoints are common entry points for attacks because they interact with users.

- Phishing emails → malicious attachments

Example: A user opens a fake invoice PDF that installs malware.

- Drive-by downloads

Example: Visiting a compromised website that silently installs malware.

- USB-based malware

Example: Plugging in an infected USB that automatically runs malicious code.

- Exploiting unpatched software

Example: Using a known vulnerability in outdated Chrome or Windows to gain access.

- Why endpoints are dangerous

- Users have access

Users can install apps, open files, and execute programs.

- Users click things

Human error is a major security weakness (links, attachments, pop-ups).

- Often weakest security point

Compared to servers or networks, endpoints usually have:

weaker configurations
inconsistent patching
less monitoring

Servers (Application / Database / File)

- Types of Servers

- Web Servers

Meaning: Host websites and handle HTTP requests.

Example: Apache or Nginx serving a company website.

- App Servers

Meaning: Run business applications and backend logic.

Example: A banking application processing transactions.

- Database (DB) Servers

Meaning: Store and manage structured data.

Example: MySQL or Oracle storing customer records.

- File Servers

Meaning: Store and share files across users or systems.

Example: Shared drive containing company documents.

- How attackers abuse servers

- Exploiting vulnerabilities (Log4j)

Example: Using Log4Shell to execute remote commands on a server.

- SQL Injection

Example: Manipulating a login form to extract entire database contents.

- Remote Code Execution (RCE)

Example: Running system commands on a vulnerable web application.

- Weak admin credentials

Example: Guessing or brute-forcing admin/admin123 to access server panel.

- Exposed services

Example: Leaving SSH, RDP, or database ports open to the internet.

- Why servers are high-value targets

- Run critical applications

Servers power business operations like payments, login systems, and APIs.

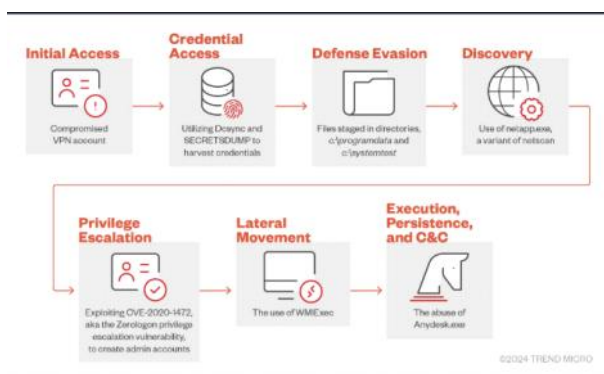
- Store sensitive data

They contain customer data, credentials, financial records, etc.

- Trusted internally

Internal systems often assume servers are safe, so attackers can move freely once inside.

Network Devices (Routers, Firewalls, VPNs)



- Devices in Network Infrastructure

- Routers

Meaning: Direct traffic between networks.

Example: Connecting internal company network to the internet.

- Firewalls

Meaning: Filter and control incoming/outgoing network traffic based on rules.

Example: Blocking unauthorized access to internal systems.

- VPN Gateways

Meaning: Provide secure remote access to internal networks.

Example: Employees connecting securely from home.

- Load Balancers

Meaning: Distribute traffic across multiple servers for performance and availability.

Example: Splitting web traffic across multiple web servers.

- How attackers abuse network devices

- Default credentials

Example: Logging into a router using admin/admin and changing settings.

- VPN vulnerabilities

Example: Exploiting a VPN bug to bypass authentication and access internal network.

- Misconfigured firewall rules

Example: Firewall accidentally allowing all inbound traffic to critical systems.

- Firmware exploits

Example: Attacking outdated router firmware to install backdoors or reroute traffic.

Cloud Systems (AWS/Azure/GCP)

- Public S3 Buckets

Meaning: Cloud storage is accidentally made public and accessible to anyone.

Example: A company stores customer records in an S3 bucket, but it is publicly readable on the internet.

SOC Detection:

Cloud security alerts (public access enabled)

Unusual external downloads of large datasets

Data exposure detected by CSPM tools

- Exposed Access Keys

Meaning: Cloud credentials (API keys/secrets) are leaked or stored insecurely.

Example: AWS access keys accidentally uploaded to GitHub.

SOC Detection:

CloudTrail alerts for unusual API usage

Login attempts from unknown IPs using keys

Secret scanning alerts from repositories

- Over-permissive IAM Roles

Meaning: Users or services are given more permissions than required.

Example: A developer account has full admin access to all cloud services.

SOC Detection:

IAM policy violation alerts

Unusual access to sensitive resources

Privilege escalation events in audit logs

- Metadata Service Abuse

Meaning: Attackers exploit cloud instance metadata to steal credentials or access tokens.

Example: SSRF attack used to access AWS metadata service and retrieve temporary credentials.

SOC Detection:

Unexpected internal metadata service requests

Abnormal instance-level API calls

EDR/cloud logs showing credential retrieval patterns

ALERT TRIAGE, TTPs & THREAT IOCs

30 June 2026 07:56

TTPs (Tactics, Techniques and Procedures) in SOC

They describe how attackers think, act, and operate during a cyber attack.

If an IOC tells you what happened, TTPs tell you how and why it happened.

SOC analysts use TTPs to:

- Detect attacks even when IOCs change
- Understand attacker intent
- Build better detections, alerts, and response Playbooks



Why TTPs important in a SOC

Imagine this real-world example:

IOC ->> "A masked person was seen"

TTP ->> "The attacker broke the lock, entered through the back door, disabled CCTV, and escaped via the fire exit"

SOC teams care more about behavior than just indicators.

TACTICS - The Goal

Tactics describe WHY the attacker is doing something: Each tactic represents a phrase of the attack lifecycle.

Tactic	Description	Example
Gain Initial Access	The attacker tries to enter the target system or network for the first time.	Sending a phishing email with a malicious attachment that installs malware when opened.
Steal Credentials	The attacker attempts to obtain usernames, passwords, or other authentication data.	Using a keylogger to capture a user's login credentials.
Move Laterally	After gaining access, the attacker spreads to other systems within the network.	Using stolen administrator credentials to log in to another server.
Exfiltrate Data	The attacker steals sensitive data and transfers it outside the victim's network.	Uploading confidential customer records to a remote server controlled by the attacker.
Maintain Persistence	The attacker ensures they can continue accessing	Creating a hidden administrator account or

tence the system even installing malware after a reboot or that starts password change. automatically at boot.

TACTICS - EXAMPLE

TACTIC	MEANING
Initial Access	How the attacker first gets in
Execution	Running malicious code
Persistence	Staying in the system
Privilege Escalation	Becoming admin
Defence Evasion	Avoiding antivirus/EDR
Credential Access	Stealing passwords
Lateral Movement	Moving to other systems
Exfiltration	Stealing data

TECHNIQUES - The Method

Techniques describe HOW the attacker achieves a tactic. Think of techniques as specific attack methods

Tactic	Short Description	Example Techniques	Example Scenario
Initial Access	The attacker gains entry into the target system or network.	- Phishing - Exploiting Public-Facing Applications - Drive-by Compromise - Valid Accounts	A user clicks a phishing email attachment, allowing the attacker to gain access to the company network.
Credential Access	The attacker steals usernames,	- Keylogging - Credential Dumping	Malware dumps credentials from LSASS

s	passwords, or (LSASS) • other authentication credentials.	Browser Password Theft • Phishing for Credentials	memory, allowing the attacker to log in as an administrator .
Later al Movement	The attacker moves from one compromised system to other systems within the network.	• Remote Desktop Protocol (RDP) • Pass-the-Hash • Pass-the-Ticket • PsExec	The attacker uses stolen administrator credentials to remotely access another server using RDP.
Exfiltration	The attacker transfers stolen data from the victim's environment to an external location.	• Exfiltration over HTTPS • Exfiltration over C2 Channel • Cloud Storage Upload • Archive Collected Data	Sensitive customer data is compressed and uploaded to an attacker-controlled cloud storage account.
Persistence	The attacker ensures continued access to the compromised system, even after reboots or password changes.	• Registry Run Keys • Scheduled Tasks • Create Local Account • Web Shell	The attacker creates a scheduled task that automatically launches malware whenever the system starts.

PROCEDURES - THE EXACT STEPS

Procedures are the attacker's exact implementation in the real world

- **Tools** - Software used by attackers to perform specific actions.
Example: Mimikatz for extracting Windows credentials.
- **Commands** - Specific instructions executed in a terminal or shell.
Example: procdump.exe -accepteula -ma lsass.exe lsass.dmp
- **Scripts** - A series of commands automated in a file.
Example: A PowerShell script that collects system information.
- **Timing** - When an attacker performs an action to avoid detection.
Example: Running malicious tasks late at night when fewer administrators are monitoring systems.

Technique: Credential Dumping

- **Description:** A technique used to obtain stored account credentials from a system.
- **Example:** procdump.exe -accepteula -ma lsass.exe lsass.dmp (creates a memory dump of the LSASS process, which can then be analyzed to recover credentials if protections are not in place).

MITRE ATT&CK

- **Description:** A global knowledge base of adversary tactics, techniques, and procedures (TTPs) used by security teams to understand, detect, and respond to cyber threats.
- **Example:** Mapping **Credential Dumping** to the ATT&CK technique T1003: OS Credential Dumping helps SOC analysts create detection rules in SIEM, EDR, and XDR platforms.

IOCs (Indicators of Compromise)

They are observable evidence that suggests a system may be compromised or under attack.

If TTPs describe attacker behavior.

IOCs are the footprints attackers leave behind.

SOC analysts hunt, detect, correlate and respond using IOCs every single day.

IOC = "Something bad happened here, and we can prove it with data."

Data Source	How it Helps in IOCs	Example
Logs	Show suspicious events such as failed logins, privilege changes, or unusual process execution.	Multiple failed login attempts from the same IP address.
Network Traffic	Reveals malicious connections, data exfiltration, or communication with known malicious IPs/domains.	A host repeatedly connecting to a known malicious IP address.
Endpoint Activity	Detects suspicious processes, file creation, registry changes, or command execution on a device.	An unknown process spawning powershell.exe with suspicious arguments.
Email Headers	Helps identify phishing by revealing the true sender, mail path, and suspicious domains.	An email claiming to be from a bank but sent from a different domain.
File Systems	Identifies malicious or modified files using hashes, locations, or unusual file names.	A newly created executable in the Startup folder with a hash matching known malware.

In a real SOC environment, IOCs help you:

IOC Use	How it Helps	Example
Trigger alerts in SIEM	SIEM compares logs with known IOCs and generates an alert when a match is found.	A firewall log shows communication with a known malicious IP, triggering an alert.
Confirm malicious activity	Matching multiple IOCs increases confidence that an attack is occurring.	A suspicious file hash and a connection to a malicious domain are found on the same endpoint.
Correlate attacks across systems	Security tools link the same IOC across multiple devices to identify the scope of an attack.	The same malicious IP appears in logs from three different servers.
Respond quickly (block, isolate, contain)	Security teams use IOCs to take immediate defensive actions.	Block a malicious IP at the firewall or isolate an infected endpoint from the network.
Write incident reports	IOCs provide evidence and a timeline of the incident for documentation.	The report includes the malicious IP, file hash, affected host, and timestamps of the attack.

Types of IOCs

1. Network-Based IOCs

These IOCs indicate suspicious or malicious activity observed in network communications.

IOC	Short Description	Small Example
Malicious IP Address	An IP known to be used by attackers.	185.220.101.45 appears in firewall logs.
Suspicious Domain	A domain used for phishing or malware.	login-secure-update.com
C2 Server Communication	A compromised device communicating with an attacker's Command-and-Control (C2) server.	An endpoint repeatedly connects to 203.0.113.50 every 5 minutes.
Unusual Ports or Protocols	Unexpected network ports or protocols that may indicate malicious activity.	A workstation making outbound connections on TCP port 4444 .

Where SOC Analysts see them

Source	Small Example
Firewall Logs	Outbound connection to a blocked malicious IP.
Proxy Logs	User accesses a known phishing website.
DNS Logs	Device repeatedly queries a suspicious domain.
IDS/IPS Alerts	Alert: "Possible C2 traffic detected."

2. Host/Endpoint-based IOCs

These IOCs indicate suspicious or malicious activity occurring inside a system (endpoint).

IOC	Short Description	Small Example
------------	--------------------------	----------------------

Suspicious Processes	Unknown or malicious programs running on the system.	powershell.exe launched with an encoded command.
Unexpected Services	New or unauthorized services created to maintain persistence.	A new service named UpdateService starts automatically.
Registry Changes	Unauthorized modifications to the Windows Registry.	A new entry added to HKCU\Software\Microsoft\Windows\CurrentVersion\Run.
New Scheduled Tasks	Tasks created to automatically execute programs.	A scheduled task runs malware.exe every hour.

Where SOC Analysts See Them

Source	Small Example
EDR/XDR	Detects a suspicious PowerShell process.
Windows Event Logs	Logs a new service installation.
Sysmon	Records creation of a new process and registry modification.
Linux Audit Logs	Shows an unauthorized user executing sudo commands.

3. File-Based IOCs

These IOCs are related to malicious or suspicious files found on a system.

IOC	Short Description	Small Example
File Hash (MD5,	A unique fingerprint used to	SHA-256 hash matches a

SHA-256)	identify a known malicious file.	known malware sample.
File Name Patterns	Suspicious or deceptive file names used by attackers.	invoice.pdf.exe
File Size Anomalies	Files with unusual sizes that may indicate malware or tampering.	A "text file" that is 50 MB in size.

Where SOC Analysts See Them

Source	Small Example
Antivirus	Detects a file hash matching known malware.
EDR	Flags a suspicious executable created on an endpoint.
Email Security Gateways	Blocks an email attachment named invoice.pdf.exe.
Sandboxes	Analyzes an unknown file and identifies it as malicious.

4. Email-Based IOCs

These IOCs are related to malicious or phishing emails.

IOC	Short Description	Small Example
Malicious Sender Email	Email sent from a known malicious or spoofed address.	support@micr0soft-login.com
Phishing Subject Lines	Subjects designed to trick users into opening the email.	"Your Account Will Be Suspended Today"
Malicious URLs	Links that lead to phishing or	https://login-verify-

	malware websites.	example.com
Header Anomalies	Unusual email header information indicating spoofing.	"From" address does not match the "Return-Path".

Where SOC Analysts See Them

Source	Small Example
Email Security Tool	Blocks an email containing a malicious attachment.
Microsoft Defender	Detects and quarantines a phishing email.
Proofpoint / Mimecast	Flags an email with a malicious URL.
User Reports	An employee reports a suspicious email to the SOC.

IOC Confidence Levels

Not all IOCs provide the same level of confidence. The more evidence that supports an attack, the higher the confidence.

Confidence Level	Short Description	Example
Low	Weak evidence; may be a false positive.	A single suspicious IP address appears in firewall logs.
Medium	Some evidence of malicious activity.	A device connects to a known phishing domain.
High	Strong evidence of compromise.	A known malware file hash is found and the file is executed.

Very High	Multiple IOCs confirm the same attack.	A malicious IP, malware hash, and suspicious PowerShell process are all detected on the same endpoint.
------------------	--	--

IOCs Vs TTPs

Professional SOC teams use both IOCs and TTPs for effective threat detection and response.

IOCs (Indicators of Compromise)	TTPs (Tactics, Techniques, and Procedures)	Example
Evidence	Behavior	IOC: Malicious IP → TTP: Credential Dumping
Shows what happened	Shows how it happened	IOC: Malware file hash → TTP: Phishing email delivery
Short-lived	Long-lived	An attacker changes IPs, but still uses the same attack technique.
Easy to change	Hard to change	A domain can be replaced, but the attacker's behavior often remains similar.
Used for alerts	Used for detection logic	SIEM alerts on a malicious hash; EDR detects PowerShell abuse as a technique.

Key Point:

- **IOCs** help identify **specific evidence** of an attack.
- **TTPs** help identify the **attacker's behavior**, even when IOCs change.

IOC -> Alert -> Investigation(Real SOC Flow)

Step	Short Description	Example
1. IOC Detected	A security tool detects a suspicious IOC.	EDR detects a known malware hash.
2. SIEM Generates Alert	SIEM receives the event and creates an alert.	Microsoft Sentinel generates a "Malware Detected" alert.
3. SOC L1 Validates IOC	The Level 1 analyst checks if the alert is legitimate.	Confirms the file hash matches a known malware database.
4. SOC Maps to TTP	The analyst identifies the attack technique using MITRE ATT&CK.	Maps the activity to OS Credential Dumping (T1003) .
5. Decision: True Positive or False Positive	Determine whether the alert represents a real threat.	The malware actually executed → True Positive.
6. Escalation or Closure	Escalate confirmed incidents or close false alarms.	Escalate to the Incident Response team for containment.

Flow:

IOC Detected → SIEM Alert → L1 Validation → TTP Mapping → True/False Positive → Escalate or Close

Alert Triage

Alert Triage is the structured process of: Quickly analyzing security alerts to decide whether they are real threats, false alarms or need escalation.

In simple words:

Alert triage = separating real attacks from noise, fast and accurately

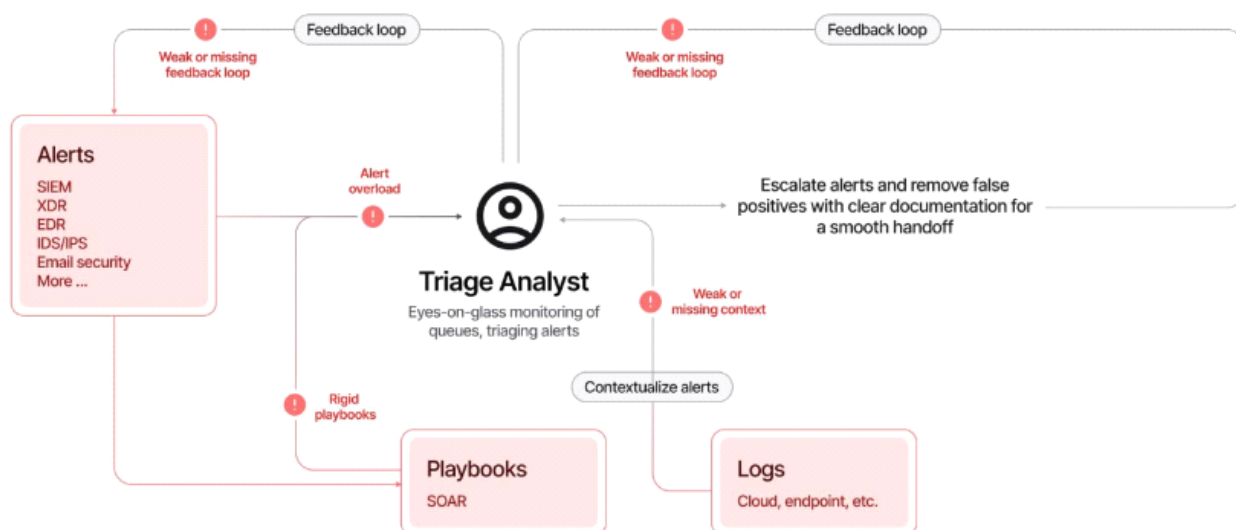
SOC environments generate thousands of alerts daily. Only a small percentage are real incidents.

Your job as a SOC analyst is to filter, prioritize, and act.

How SOC Data Becomes Alerts (Simple Flow)

Stage	Short Description	Example
1. Event Occurs	Something happens in a system (normal or suspicious).	User logs in, file is downloaded, or a process starts.
2. Logging	The system records the event in logs.	Windows logs a login attempt in Event Viewer.
3. Log Collection	Logs are collected and sent to a central security platform.	Firewall and endpoint logs sent to a SIEM .
4. SIEM/EDR Processing	Security tools analyze logs for patterns, rules, or IOCs.	Detects repeated failed logins from same IP.
5. Alert Generation	A meaningful suspicious pattern triggers an alert.	Alert: "Possible brute force attack detected."
6. SOC Triage	Analysts review alerts instead of raw logs.	SOC investigates 50 alerts instead of millions of logs.

Most logs are normal, but **alerts filter out the noise** so SOC analysts focus only on **suspicious or important activity** instead of reviewing everything manually.



Why Alert Triage Is Critical

Without proper triage:

- SOC teams drown in alerts
- Real attacks get missed
- Response is delayed
- Business impact increases

With good triage:

- False positives are reduced
- Real threats are caught early
- SOC becomes efficient and trusted

SOC analysts are promoted based on triage quality, not number of alerts closed.

Triage decides whether an alert becomes an incident

Alert Properties

Property	Meaning (SOC L1)	Example
Alert Time	When the alert was generated	Mar 21, 15:35
Alert Name	Summary of what triggered	Unusual Login Location
Alert Severity	Urgency assigned by detection	Low / Medium / High / Critical
Alert Status	Current lifecycle state	New / In Progress / Closed
Alert Verdict	L1 classification outcome	True Positive / False Positive
Alert Assignee	Analyst handling the alert	Assigned Analyst Name
Alert Description	Explanation of what the alert means	Detailed description of the suspicious activity
Alert Fields	Contextual values that led to the alert	Affected Hostname, Entered Commandline, etc.

Alert Prioritisation

Alert prioritisation is the process of deciding which security alerts should be investigated first in a SOC. It helps analysts focus on the most important threats and avoid wasting time on noise.

Why it is important

- Prevents duplicate work (same alert reviewed multiple times)
- Reduces alert fatigue
- Ensures critical threats are handled first
- Improves SOC efficiency and response time

Alert Prioritisation Steps

1. Filter Alerts

- Remove alerts that are already:
 - Investigated
 - Assigned to another analyst
 - Closed or resolved

Goal: Focus only on new and active alerts

Example: Ignore an alert already marked "Under Investigation" by another SOC analyst.

2. Sort by Severity

- Prioritize based on impact level:
 - **Critical** → **High** → **Medium** → **Low**
- Critical alerts are more likely to represent real attacks.

Example:

A "Malware execution detected" alert (Critical) is handled before a "Port scan detected" alert (Low).

3. Sort by Time (FIFO principle)

- Investigate **older alerts first**
- Older alerts may indicate ongoing attacks causing more damage

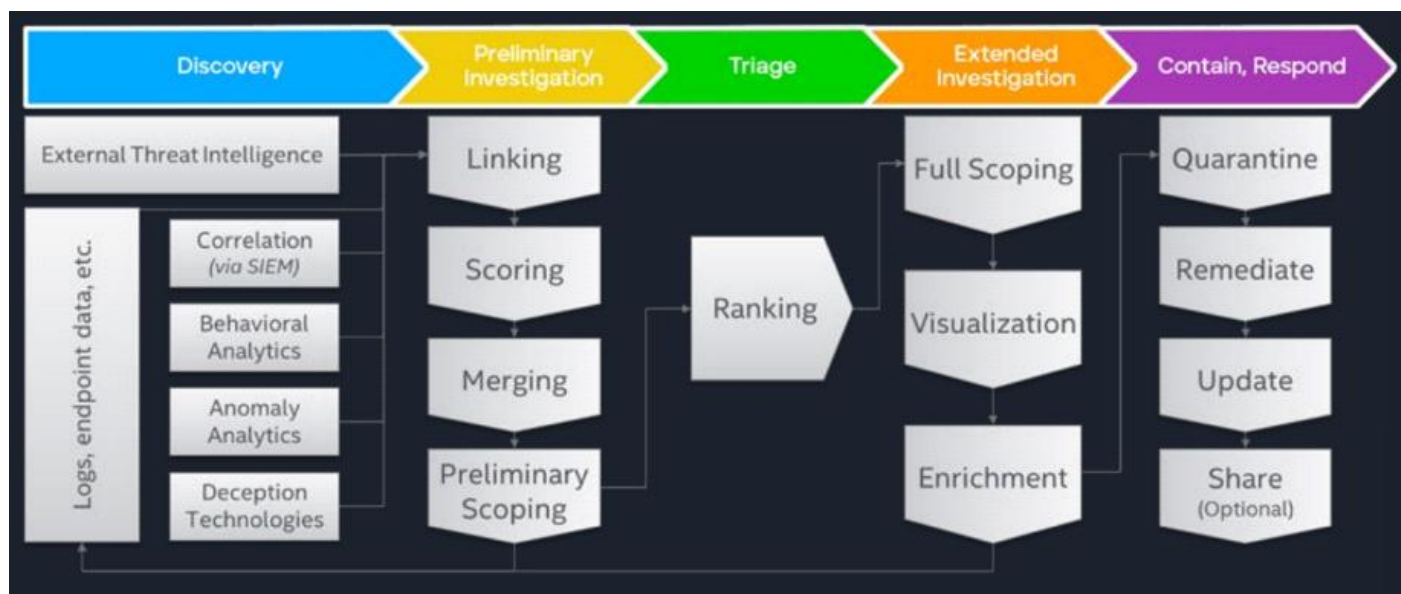
Example:

An alert from 2 hours ago showing data exfiltration is handled before a 10-minute-old suspicious login attempt.

Final Priority Order

1. New + Unassigned alerts
2. Critical severity
3. Older alerts first

Alerts



Alert Triaging

Initial Actions

Alert triaging is the initial process of reviewing, organizing, and taking ownership of a security alert before starting a full investigation.

Initial Actions in Alert Triaging

1. Assign Alert to Yourself

- Take ownership of the alert in the SIEM/EDR system
- Ensures no duplicate investigation by other analysts

Example:

SOC analyst assigns "Suspicious Login Attempt" alert to their name.

2. Move Alert to "In Progress"

- Update alert status to show it is being actively investigated
- Prevents other analysts from working on the same alert

Example:

Alert status changes from **New** → **In Progress**

3. Understand Alert Details

- Review key information before investigation:
 - Alert name
 - Description
 - Source logs
 - Indicators (IP, user, process, file hash)

Example:

Analyst reviews:

- IP: 185.220.101.45
- User: admin
- Alert: "Multiple failed login attempts"

Investigation

Investigation is the most critical and complex stage of alert triaging, where the SOC analyst analyzes logs and evidence to determine whether the alert is malicious or benign.

This step requires combining technical

knowledge + log analysis + threat intelligence to understand what really happened.

Workbooks / Playbooks

- Also called **runbooks**
- Step-by-step instructions for investigating specific alert types
- Help L1 analysts stay consistent and faster

Example:

A "Suspicious Login" workbook may include:

- Check IP reputation
- Verify user login history
- Look for impossible travel activity

Investigation Steps

1. Identify the Target (Who is affected?)

- Determine the impacted entity:
 - User
 - Hostname
 - Cloud account
 - Website or service

Example:

Alert affects user: john.doe on workstation
PC-102

2. Understand the Action (What happened?)

- Identify the type of activity:
 - Suspicious login
 - Malware execution
 - Phishing attempt
 - Data download

Example:

Multiple failed login attempts detected on an admin account

3. Analyze Surrounding Events

- Check logs **before and after the alert**
- Look for related suspicious activity

Example:

After login failure → successful login from same IP → unusual file download

4. Use Threat Intelligence

- Verify indicators using external/internal

intelligence sources:

- o Malicious IP reputation
- o Known phishing domains
- o File hash databases

Example:

IP address found in threat intelligence feed
as a known botnet node

Key Outcome

After investigation, the analyst decides
whether the alert is:

- **True Positive (real attack)**
- **False Positive (benign activity)**

ALERT REPORTING, ESCALATION & CYBER KILL CHAIN

30 June 2026 20:57

The **Cyber Kill Chain** is a cybersecurity framework that describes the stages of a cyberattack from the attacker's perspective. It was developed by Lockheed Martin to help organizations detect and stop attacks before they achieve their objective.

The seven stages are:

1. Reconnaissance

- The attacker gathers information about the target.
- Examples: searching social media, scanning networks, identifying employees, collecting email addresses.

2. Weaponization

- The attacker creates a malicious payload.
- Examples: combining malware with a phishing document or exploit.

3. Delivery

- The attacker sends the weapon to the target.
- Common methods include phishing emails, malicious websites, infected USB drives, or compromised software.

4. Exploitation

- The malicious code is triggered by exploiting a vulnerability or tricking the user.
- Examples: opening a malicious attachment or exploiting an unpatched software flaw.

5. Installation

- Malware is installed on the victim's system.
- The attacker may establish persistence so the malware survives reboots.

6. Command and Control (C2)

- The infected system connects to the attacker's server to receive commands.

- This allows the attacker to remotely control the compromised device.

7. Actions on Objectives

- The attacker carries out their goal.
- Examples include:
 - Stealing sensitive data
 - Encrypting files with ransomware
 - Disrupting systems
 - Moving laterally through the network

Simple example

A phishing attack might follow this sequence:

- **Reconnaissance:** The attacker finds employee email addresses.
- **Weaponization:** They create a malicious PDF.
- **Delivery:** They email the PDF to employees.
- **Exploitation:** An employee opens the file.
- **Installation:** Malware is installed.
- **Command and Control:** The malware contacts the attacker's server.
- **Actions on Objectives:** The attacker steals confidential company data.

7 Stages Of Cyber Kill Chain



Phase	Description	Key Ethical Hacking Activity
Reconnaissance	Gathering intel on the target (OSINT).	Passive & Active footprinting.
Weaponization	Coupling an exploit with a backdoor (e.g., a PDF with a script).	Payload crafting with Metasploit/Cobalt Strike.
Delivery	Sending the weapon to the victim (Email, USB, Web).	Phishing simulations.
Exploitation	The "Boom" moment—triggering the vulnerability.	Executing a buffer overflow or SQL injection.
Installation	Installing persistent malware on the victim's asset.	Setting up persistent shells or rootkits.
C2 (Command)	Establishing a remote channel for control.	Configuring C2 frameworks like Mythic or Havoc.
Actions	Final goal: Data theft, encryption, or destruction.	Data exfiltration testing (DLP bypass).

Reconnaissance (Information Gathering)

Definition

- First stage of the Cyber Kill Chain.
- Attacker collects information about the target before launching an attack.
- Goal: Understand the target's systems, people, and security.

Attacker's Objective

- Gather maximum information with minimum detection.
- Identify possible weaknesses to exploit.

Common Information Collected

- Employee email addresses
- Company domains and subdomains
- Technologies used (e.g., WordPress, Apache, IIS)
- Employee details from LinkedIn
- Leaked usernames and passwords

Examples

- Searching company employees on LinkedIn.
- Finding email addresses from the company website.
- Discovering a company uses WordPress.
- Checking if company credentials are available in public data leaks.

Tools & Techniques

- **Google Dorking** – Advanced Google searches to find exposed information.
 - *Example:* Finding publicly accessible PDF documents.

- **WHOIS Lookup** - Finds domain registration details.
 - *Example:* Owner and registration date of example.com.
- **DNS Enumeration** - Identifies domains, subdomains, and DNS records.
 - *Example:* Discovering mail.example.com.
- **OSINT (Open Source Intelligence)** - Collecting publicly available information.
 - *Example:* Using LinkedIn, GitHub, and social media to gather employee details.

SOC (Defensive View)

- Monitor excessive DNS queries.
- Detect network scanning activity.
- Watch for phishing attempts based on publicly available information (OSINT).

Key Point

Reconnaissance = "Know your target before attacking."

One-line example:

An attacker searches LinkedIn to find employees, uses Google Dorking to locate exposed documents, and performs a WHOIS lookup to gather information before sending a phishing email.

Weaponization - Short Notes

Definition

- Second stage of the Cyber Kill Chain.
- Attacker creates a malicious payload and combines it with an exploit.

Key Terms

- **Payload** - The malicious code that executes after exploitation.
 - *Example:* Ransomware, spyware, reverse shell.
- **Exploit** - The method used to take advantage of a vulnerability.
 - *Example:* Exploiting an unpatched software flaw.

Attacker's Objective

- Build a weapon that can successfully

compromise the target.

- Combine an exploit with malware to maximize the chances of infection.

Examples

- Malware embedded in a PDF file.
- Reverse shell hidden inside a Microsoft Word macro.
- Exploit targeting an unpatched web server or application.

Common Techniques

- Embedding malware in documents.
- Creating malicious Office macros.
- Packaging exploits with ransomware or spyware.
- Using exploit kits to automate attacks.

SOC (Defensive View)

- **File Hash Analysis** - Compare file hashes with known malicious hashes.
- **Malware Sandboxing** - Execute suspicious files in an isolated environment to observe behavior.
- **Exploit Signature Detection** - Detect known exploit patterns using security tools (IDS/IPS, antivirus).

Key Point

Weaponization = "Build the attack weapon before delivering it."

One-line example:

An attacker embeds ransomware inside a PDF file and prepares it to be sent in a phishing email.

Delivery - Short Notes

Definition

- Third stage of the Cyber Kill Chain.
- The attacker sends the prepared weapon (payload) to the target.

Attacker's Objective

- Deliver the malicious file or link to the victim.
- Trick the victim into opening or interacting

with it.

Common Delivery Methods

- **Phishing Email** - Fake email containing a malicious link or attachment.
- **Malicious Attachment** - Infected PDF, Word, Excel, or executable file.
- **Drive-by Download** - Malware automatically downloads when visiting a compromised website.
- **USB Drop** - Infected USB drive left for someone to plug into a computer.
- **Compromised Advertisements (Malvertising)** - Malicious ads that redirect users to harmful websites.

Example

- An HR employee receives an email with an attachment named "**Resume.pdf.exe**" and opens it, unknowingly executing malware.

SOC (Defensive View)

- **Email Gateway Filtering** - Blocks spam, phishing emails, and malicious attachments.
- **URL Reputation Checking** - Prevents access to known malicious websites.
- **Attachment Sandboxing** - Opens suspicious attachments in a secure environment to detect malware before delivery.

Key Point

Delivery = "Send the weapon to the target."

One-line example:

An attacker sends a phishing email with a malicious attachment disguised as a job applicant's resume.

Exploitation - Short Notes

Definition

- Fourth stage of the Cyber Kill Chain.
- The attacker exploits a vulnerability or tricks the user to execute the malicious code.

Attacker's Objective

- Trigger the exploit and gain access to the

target system.

- Execute the malicious payload successfully.

Common Exploitation Methods

- **User clicks a malicious link** - Opens a fake website or downloads malware.
- **Buffer Overflow** - Exploits a software vulnerability to execute malicious code.
- **Outdated Plugin Exploitation** - Takes advantage of unpatched software or plugins.
- **Macro Execution** - User enables macros in a malicious Microsoft Office document.

Examples

- A user clicks a phishing link and downloads malware.
- An attacker exploits an outdated web server plugin.
- A victim enables macros in a malicious Word document.

SOC (Defensive View)

- Monitor for exploit attempts using **IDS/IPS**.
- Keep systems and software **patched and updated**.
- Block suspicious macro execution.
- Detect unusual application behavior with **Endpoint Detection and Response (EDR)** tools.

Key Point

Exploitation = "Trigger the vulnerability to execute the attack."

Important: No exploitation = No compromise.

This is a critical stage where SOC teams aim to detect and stop the attack before malware is installed.

One-line example:

A user enables macros in a malicious Word document, allowing the attacker's code to run on the system.

Installation - Short Notes

Definition

- Fifth stage of the Cyber Kill Chain.
- Malware is installed on the victim's system and establishes persistence.

Attacker's Objective

- Ensure the malware stays active on the system.
- Maintain long-term access even after reboot or system cleanup attempts.

What is Persistence?

- A technique used to keep malware running continuously.
- Means: *"Even if the system restarts, I still remain active."*

Common Persistence Techniques

- **Registry Run Keys** - Malware adds entries in Windows registry to auto-start.
- **Scheduled Tasks** - Malware runs at specific times automatically.
- **Startup Folders** - Malware placed in startup directories to execute on boot.
- **Backdoor Accounts** - Creating hidden or admin user accounts for access.

Examples

- Malware adds itself to Windows startup so it runs every time the system boots.
- A hidden scheduled task runs a script every hour to reconnect to attacker server.

SOC (Defensive View)

- **Endpoint Detection & Response (EDR)** - Detects suspicious installation behavior.
- **Registry Monitoring** - Watches changes in critical registry keys.
- Detect unusual startup programs or scheduled tasks.
- Identify unauthorized user account creation.

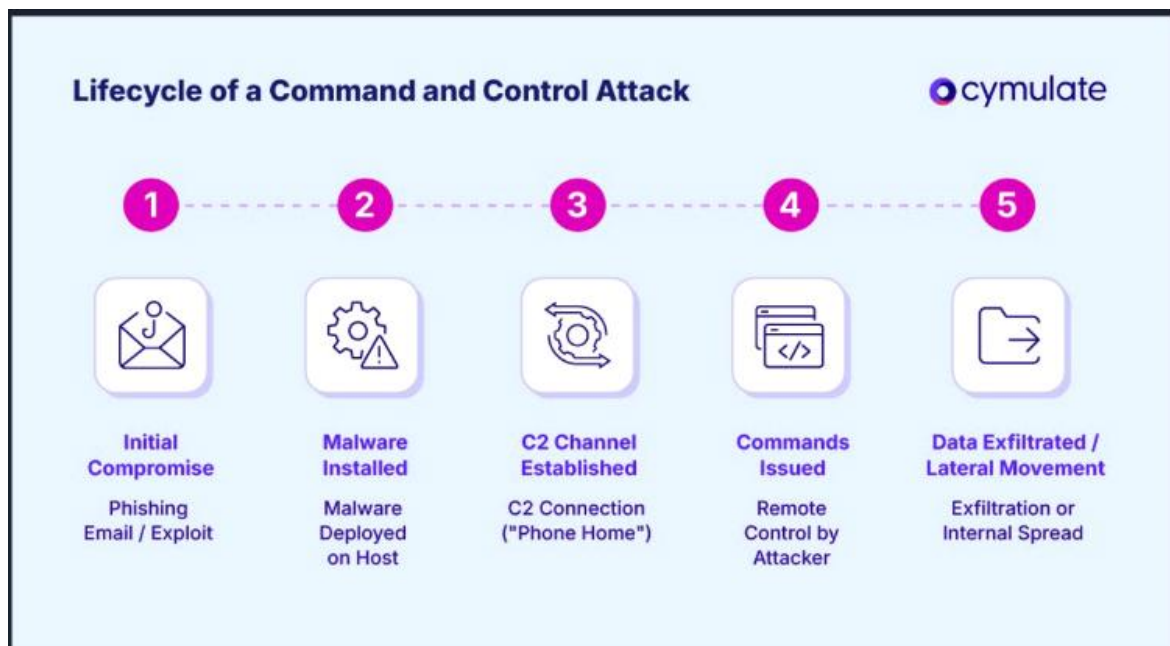
Key Point

Installation = "Malware is installed and made persistent on the system."

One-line example:

A trojan installs itself using a registry run key so it automatically starts every time the computer boots.

Command & Control (C2)



Definition

- Sixth stage of the Cyber Kill Chain.
- The infected system (bot) connects to the attacker's server to receive commands.

What happens here?

- The compromised device establishes communication with the attacker's infrastructure.
- This allows the attacker to remotely control the system.

Reason:

To maintain remote access and control over the infected machine after compromise.

Common C2 Techniques

1. Beaconing (e.g., every 60 seconds)

- The malware "checks in" with the attacker at regular intervals.

Reason:

To avoid detection by appearing like normal periodic network traffic.

2. DNS Tunneling

- Malware sends data through DNS queries instead of normal traffic.

Reason:

DNS traffic is often less monitored, helping

attackers bypass security controls.

3. HTTPS-based C2

- Communication happens over encrypted HTTPS connections.

Reason:

Encryption hides malicious traffic inside normal-looking web traffic.

SOC (Defensive View)

Abnormal Outbound Traffic

- Monitoring unusual data leaving the network.

Reason:

Compromised systems often send data to external attacker-controlled servers.

Beaconing Pattern Detection

- Detecting regular, repetitive communication intervals.

Reason:

Malware often checks in at fixed intervals, unlike normal user behavior.

Known Bad IPs / Domains

- Blocking or flagging connections to malicious infrastructure.

Reason:

Attackers reuse infrastructure that can be identified and blacklisted.

Key Point

C2 = "Remote control channel between attacker and infected system."

One-line example

A compromised computer sends encrypted HTTPS requests every 60 seconds to a malicious server to receive instructions from the attacker.

Actions on Objectives - Short Notes

Definition

- Final stage of the Cyber Kill Chain.

- Attacker executes the actual goal after gaining control of the system.

What happens here?

- The attacker performs the intended malicious activity.
- This is the stage where real impact and damage occur.

Reason:

All earlier stages (reconnaissance → C2) are preparation; this stage is the actual execution of the attacker's goal.

Common Objectives

1. Data Theft

- Stealing sensitive information like files, emails, or databases.

2. Ransomware Deployment

- Encrypting files and demanding payment for decryption.

3. Credential Dumping

- Extracting usernames and passwords from the system.

4. Lateral Movement

- Moving across different systems in the network.

5. Financial Fraud

- Unauthorized money transfers or payment manipulation.

SOC (Defensive View)

- Detect unusual file access or bulk data transfer.
- Monitor privilege escalation and credential dumping tools.
- Identify abnormal encryption activity (ransomware behavior).
- Track lateral movement between systems.
- Alert on suspicious financial transactions

or account activity.

Key Point

Actions on Objectives = "Attacker achieves their final goal and causes real damage."

One-line example

An attacker steals customer database files from a company server and encrypts systems with ransomware to demand payment.

Standard Hacking Methodologies

1. Reconnaissance: Collecting information (IPs, DNS, employee names)
2. Scanning: Using tools like Nmap or Nessus to find open ports and live services
3. Gaining Access: This is the actual "hack" - breaking through the perimeter or using credential
4. Maintaining Access: Ensuring you don't lose your connection if the user reboots or the networks resets (Persistence).
5. Clearing Tracks: Deleting logs and removing tools to avoid detection by the Blue Team (Defenders).

Cyber Kill Chain vs Hacking Methodology

Cyber Kill Chain	Hacking Methodology	What happens (short description)
Reconnaissance	Reconnaissance	Attacker gathers information about the target (emails, domains, employees, technologies)
Weaponization	Exploit preparation	Malware and exploit are created or prepared
Delivery	Payload delivery	Malicious file or link is sent to the victim
Exploitation	Gaining Access	Vulnerability is triggered

ion	access	to execute malicious code
Installat	Maintain	Malware is installed and
ion	ing	persistence is established
	access	
Command & Control	Persiste	Compromised system connects
(C2)	nt	to attacker's server for
	control	remote control
Actions	Post-	Attacker performs final
on	exploita	activities like data theft,
Objective	tion	ransomware, or lateral
s		movement

Alert Reporting

What is Alert Reporting?

Alert reporting is the process of formally documenting security alerts and their investigation details.

It includes:

- What was detected
- What was analyzed
- What conclusion was reached
- What action was taken or recommended

Purpose of Alert Reporting

- Maintain a clear record of security incidents
- Support incident tracking and follow-ups
- Help SOC teams share information efficiently
- Improve future detection and response

SOC Golden Rule

"If it's not documented, it didn't happen."

Key Point

Alert reporting ensures every security alert is properly recorded, understood, and actionable for future reference.

Why Alert Reporting Matters

- **Creates audit trail** - Maintains a complete record of what happened for future review and compliance.
- **Enables handover between shifts** - Helps the next SOC shift quickly understand ongoing alerts and investigations.
- **Supports incident response** - Provides clear context for faster and more accurate response actions.
- **Protects analysts legally** - Acts as formal evidence of actions taken and decisions made during investigations.
- **Helps improve detections** - Allows teams to refine rules, reduce false positives, and improve security monitoring.

Example: Tier-1 Alert Report (Short)

Summary

PowerShell executed with an encoded command triggered by a Word document on a finance user system.

Analysis

Execution occurred outside business hours. Parent process was **winword.exe**. External network connection was observed.

Verdict

True Positive - suspicious execution.

Recommendation

Escalate to SOC L2 for containment.

What is Escalation?

Escalation means:

"This alert is beyond Tier-1 authority and requires higher expertise or action."

It means

- The alert cannot be fully handled at Tier-1 level.

- It is passed to a higher SOC level (Tier-2 or Tier-3) for deeper investigation or response.
- Tier-1 does **not fix incidents**
- Tier-1 **identifies, validates, and escalates correctly**

When Should Tier-1 Escalate?

Tier-1 should escalate an alert when **any** of the following conditions are met:

Condition	Example
Confirmed malicious activity	Malware execution detected
Privileged account involved	Admin or domain user activity
Critical asset affected	Server, database, or domain controller impacted
Multiple alerts correlated	Phishing email followed by suspicious execution
Data risk exists	Possible data exfiltration activity
Policy requires escalation	Severity marked High or Critical

Example: Tier-1 Escalation Note

Escalation Reason

Confirmed suspicious PowerShell execution with external communication.

Evidence Attached

Process tree, command line, destination domain.

Severity

High

Recommended Action

Endpoint isolation and memory analysis.

What is SOC Communication?

Definition

SOC communication is the structured exchange of security-related information between teams to ensure incidents are understood and handled correctly.

Communication Flow

- Analyst → Analyst
- Analyst → Incident Response (IR) team
- Analyst → IT/Admin team
- SOC → Management

Purpose

- Share security findings clearly and quickly
- Ensure proper response actions are taken
- Coordinate between technical and non-technical teams
- Reduce confusion during incidents

Key Role of a SOC Analyst

- Translate technical findings into clear, actionable information
- Communicate risk in a way different teams can understand and act on

SOC Communication (The Most Underrated Skill) - 2

Communication Principles (SOC Standard)

- Clear
- Factual
- No assumptions
- No panic language
- No blame

Good vs Bad Communication Example

✗ Bad

"System hacked badly!!!"

✓ Good

"Suspicious activity detected, under investigation."

SOC Communication (The Most Underrated Skill) - 3

Communication Types in SOC

1. Internal SOC Communication

Used within the SOC team for coordination and workflow continuity.

Used during:

- Shift handover
- Escalation
- Collaboration between analysts

Example (Handover Note)

Alert escalated to L2. Endpoint pending isolation. Monitoring ongoing.

SOC Communication (The Most Underrated Skill) - 4

IT / Admin Communication

Used when a **technical action is required** from IT or system administrators.

Example (Correct)

Please isolate FIN-LAP-07 from the network as suspicious activity was detected.

Example (Incorrect)

"There is malware everywhere"

SOC Communication (The Most Underrated Skill) - 5

Management Communication (High-Level)

Management focuses on **business impact and current status**, not technical details like logs or commands.

What to Include

- What happened (in simple terms)
- Impact on business
- Current status of investigation

- Risk level (if needed)

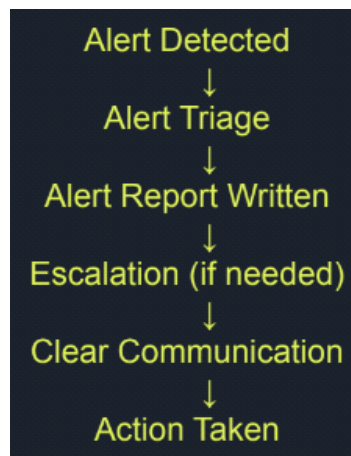
Example (Correct)

Suspicious activity detected on one finance user system. No evidence of data exfiltration so far. Incident under investigation.

Example (Not Suitable)

PowerShell encoded command executed via winword.exe with external C2 connection on port 443.

How Reporting, Escalation & Communication Fit Together



Miss any step -> SOC failure

MALWARE FOR SOC

01 July 2026 07:20

What is Malware?

Malware is any computer program or software that is used to steal data or inflict damage on computer or software systems. Malware includes various types of cyber threats such as viruses, adware, spyware, and ransomware. Most often, the goal of cyber attacks is to use the malware for financial gain.

When consumers and work-from-anywhere users are the victims of a malware attack, they may experience the following on their devices:

1. **A slow computer** that slows down internet speed and software applications.
2. **Frequent device/machine crashes** or freezes during normal use.
3. **A ton of pop-up ads**, indicating [adware](#). Clicking on these ads can launch malicious code that causes further damage.
4. **A loss of disk space**. A sudden loss of available disk space could be a result of malware on the hard drive.
5. **A swell in internet activity** that does not correlate with user behavior, can result when malware automatically accesses the internet.
6. **An overworked system** due to malware taking up valuable resources.
7. **New toolbars, extensions, and a different home page** or fraudulent website where the malware has redirected the browser.

Types of Malware

1. Virus

A computer virus is a type of malicious software, or malware, that spreads between computers and causes damage to data and software. A key thing to know about computer viruses is that they are designed to spread across programs and systems. Computer viruses typically attach to an executable host file, which results in their viral codes executing when a file is opened.

Common Signs of a Computer Virus:

- 1. Slow performance** - Computer, apps, or internet run slower than normal.
- 2. Frequent pop-ups** - Unwanted pop-up windows appear.
- 3. Programs malfunction** - Apps close unexpectedly or won't open.
- 4. Automatic logouts** - Accounts log out without your action.
- 5. System crashes** - Computer freezes, restarts, or shows unusual errors.
- 6. Unknown emails sent** - Emails are sent from your account without your knowledge.
- 7. Browser changes** - Homepage or browser settings change unexpectedly.

How Do computer Viruses Work?

Computer viruses are malicious programs that either activate immediately or lie dormant until triggered. They work in the following four distinct phases:

- **Dormant phase:** Once the virus enters the system, it stays hidden without causing immediate harm. It silently waits to avoid detection.
- **Propagation phase:** In this phase, the virus begins replicating itself, copying into files, folders, or programs to spread across the system. It can even spread to other systems through shared files.

- **Triggering phase:** Here, a specific action or event, such as clicking an app, opening a file, or downloading software, activates the virus.
- **Execution phase:** Once triggered, the virus runs its malicious code. This is when damage occurs. It can result in data corruption, system slowdown, or the stealing of sensitive information.

SOC Detection:

1. Unknown process spawning
2. Suspicious file modification
3. Antivirus Alert

2. [WORM](#)

A worm virus refers to a malicious program that replicates itself, automatically spreading through a network. The worm virus exploits vulnerabilities in your security software to steal sensitive information, install backdoors that can be used to access the system, corrupt files, and do other kinds of harm.

How to Tell if Your Computer Has a Worm:

- **Slow performance** - Computer becomes slow or programs crash.
- **Missing or new files** - Files disappear or unfamiliar files appear.
- **Low disk space** - Worms replicate, quickly using up hard drive storage.

SOC Detection:

1. Sudden network traffic spike
2. Same payload across multiple hosts
3. Lateral scanning behavior

3. [Trojan](#)

A Trojan Horse Virus is a type of malware that downloads onto a computer disguised as a legitimate program. The delivery method typically sees an attacker use social engineering to hide malicious code within legitimate software to try and gain users' system access with their software.

How to recognize a trojan virus

A Trojan horse virus can often remain on a device for months without the user knowing their computer has been infected. However, telltale signs of the presence of a Trojan include computer settings suddenly changing, a loss in computer performance, or unusual activity taking place. The best way to recognize a Trojan is to search a device using a Trojan scanner or malware-removal software.

What it does:

1. Open backdoor
2. Steal data
3. Installs additional malware

SOC Detection:

1. Unusual outbound traffic
2. Unknown services running
3. Suspicious startup entries

4. [Ransomware](#)

Ransomware is a form of malware.

Cybercriminals use ransomware as a tool to steal data and essentially hold it hostage. They only release the data when they receive a ransom payment. Organizations most vulnerable to ransomware attacks hold sensitive data, such as personal information, financial data, and intellectual property.

Attack flow:

1. Phishing email
2. User clicks attachment
3. Malware installs
4. File encrypted
5. Ransom note displayed



SOC indicators:

1. Mass file renaming
2. High CPU usage
3. Shadow copy deletion
4. Unusual encryption activity
5. Spyware

Spyware is malicious software that enters a user's computer, gathers data from the device and user, and sends it to third parties without their consent. Attackers use it to track, steal, and sell user data, such as internet usage, credit card, and bank account details, or steal user credentials to spoof their identities.

How to tell if you have a spyware:

Despite spyware being designed to go undetected, there are several telltale signs that could be indicators of a device being infiltrated. These include:

- Negative hardware performance, such as:

- A device running slower than usual
- Devices suffering frequent crashes and freezes
- A drop in application or browser performance, such as:
 - Pop-up ads repeatedly appear in browsers
 - Unusual error messages
 - Unexpected browser changes
 - New icons appearing in the taskbar
 - Browser searches redirect to new search engines

SOC Detection:

1. Strange outbound connections
2. DNS queries to unknown domains
3. Data exfiltration alerts

6. [Rootkit](#)

A rootkit is a stealthy type of malicious software designed to hide its presence and maintain privileged access on a compromised system. It manipulates core operating system components to evade detection, enabling persistent control, data exfiltration, or staging of further attacks. Rootkits often support advanced threats by disabling logging, hiding files, and masking network activity.

Dangerous Because:

1. Hides Processes
2. Hides files
3. Hides registry entries
4. Very difficult to detect

SOC Detection:

1. Mismatch b/w user-mode and kernel-mode results
2. Integrity check failures

3. Unusual driver loads

Comparison

Type	Needs User?	Spreads Automatically?	Primary Goal
Virus	Yes	No	Infect files
Worm	No	Yes	Spread rapidly
Trojan	Yes	No	Backdoor
Ransomware	Yes	Sometimes	Encrypt files
Spyware	Yes	No	Steal data
Rootkit	No	No	Hide malware

SOC Analyst Mindset

When you see an alert, ask:

- Is this malware delivery?
- Is it persistence?
- Is it lateral movement?
- Is data being exfiltrated?
- Is this encryption behavior?

SOC L1 is about:

- Detect
- Validate
- Escalate

PHISHING & SOCIAL ENGINEERING

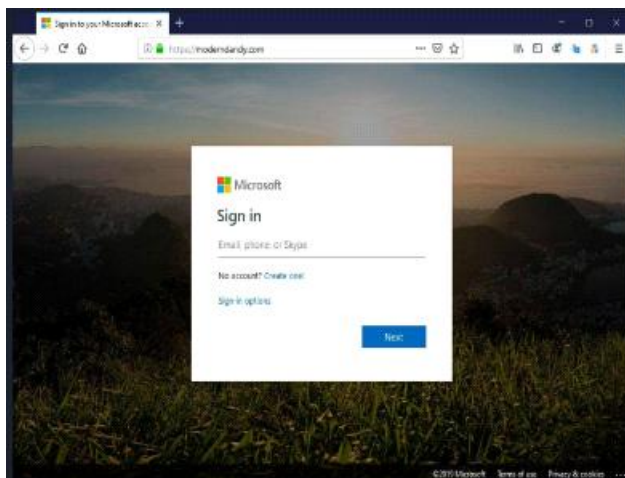
02 July 2026 16:19

WHAT IS PHISHING?

Phishing is a social engineering attack where attackers trick users into:

- Revealing credentials
- Clicking malicious links
- Downloading malware
- Transferring money
- Installing remote access tools

It attacks human psychology, not just systems



EMAIL PHISHING

Email phishing is a cyberattack where attackers send fake emails that appear to come from trusted organizations to trick users into revealing sensitive information or installing malware.

How it works:

- a. The victim receives a fraudulent email.
- b. The email looks legitimate (e.g., from a bank, Microsoft, or a courier service).
- c. It contains a malicious link, fake login page, or infected attachment.

- d. The user clicks the link, opens the attachment, or enters login credentials.
- e. The attacker steals sensitive information or installs malware on the victim's device.

Common tactics:

- o **"Your account will be suspended"** - Creates urgency to make the user act quickly.
- o **"Invoice attached"** - Tricks users into opening a malicious attachment.
- o **"Click to reset password"** - Leads to a fake login page that steals credentials.
- o **"Salary increment details"** - Uses curiosity or workplace relevance to lure employees.
- o **"Courier delivery failed"** - Encourages users to click a malicious tracking or redelivery link.

SOC Detection Indicators

- **Email from spoofed domain** - The sender's address is forged to appear as a trusted organization.
- **Lookalike domain** (e.g., *micr0soft.com*) - Attackers use similar-looking domain names to deceive users.
- **Suspicious attachments** (*.zip, .html, .exe, .docm*) - File types commonly used to deliver malware.
- **URL redirect chains** - Links that pass through multiple websites to hide the malicious destination.
- **SPF/DKIM/DMARC failure** - Email authentication checks fail, indicating the message may be spoofed or fraudulent.



SPEAR PHISHING

Spear phishing is a targeted phishing attack aimed at a specific individual or organization. Attackers use publicly available information to create highly convincing and personalized emails.

How it works:

1. The attacker gathers information from sources like LinkedIn, company websites, social media, and employee profiles.
2. A personalized email is crafted to appear as if it comes from a trusted person.
3. The victim is tricked into transferring money, sharing credentials, or opening a malicious file.
4. The attacker gains unauthorized access or causes financial loss.

Common tactics:

- **Executive impersonation** - Pretending to be a CEO, CFO, or manager.
- **Business Email Compromise (BEC)** - Requesting urgent fund transfers or sensitive information.
- **Fake vendor invoices** - Sending fraudulent payment requests.
- **Urgent business requests** - Pressuring employees to act quickly without verification.

- **Personalized messages** - Using employee names, job roles, or company details to build trust.

Why It's Dangerous:

- Looks extremely legitimate
- Often bypasses spam filters
- High financial damage

WHALING

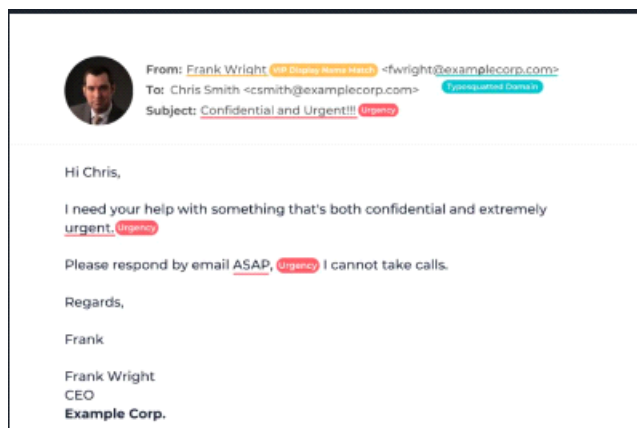
Whaling is a type of spear phishing that specifically targets high-level executives such as CEOs, CFOs, directors, or other senior leaders to steal sensitive information or authorize fraudulent transactions.

How it works:

1. The attacker researches the executive and organization.
2. A highly convincing email is sent, often impersonating a trusted partner, board member, or government authority.
3. The email requests confidential data, wire transfers, or login credentials.
4. The executive responds, leading to financial loss or data compromise.

Common tactics:

- **Fake legal or regulatory notices** - Claims of audits, lawsuits, or compliance issues.
- **Urgent wire transfer requests** - Pressuring executives to approve large payments.
- **Board member impersonation** - Pretending to be a company director or investor.
- **Confidential document requests** - Asking for sensitive financial or business information.
- **Executive account verification** - Fake requests to confirm passwords or account details.



SMISHING & VISHING

Smishing and vishing are phishing attacks that use text messages (SMS) or phone calls to trick victims into revealing sensitive information or performing fraudulent actions.

How it works:

1. The attacker contacts the victim via SMS (smishing) or a phone call (vishing).
2. They impersonate a trusted organization, such as a bank, courier, or government agency.
3. The victim is urged to click a malicious link, share an OTP, or provide personal information.
4. The attacker steals credentials, money, or gains unauthorized account access.

Common tactics:

- **Smishing:** "Your bank account is blocked. Click here to verify."
- **Smishing:** "Courier delivery failed. Update your address."
- **Vishing:** "I'm from the bank's fraud department. Tell me your OTP."
- **Vishing:** "Your account has suspicious activity. Verify your identity immediately."
- **Urgency and fear** - Creating panic to pressure victims into acting quickly.

PHARMING

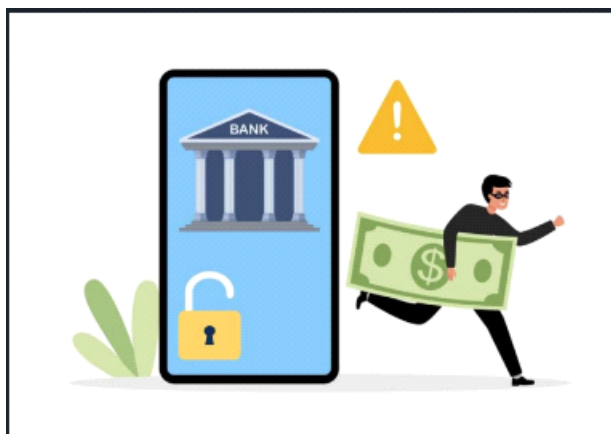
Pharming is a cyberattack that redirects users to a fake website even when they enter the correct website address. Unlike phishing, the redirection happens silently without the user clicking a malicious link.

How it works:

1. The attacker compromises DNS settings or the victim's device.
2. The user types the legitimate website address.
3. The request is secretly redirected to a fake website.
4. The victim enters login credentials or sensitive information.
5. The attacker steals the data.

Common tactics:

- **DNS poisoning** - Manipulating DNS records to redirect users.
- **Malware-based redirection** - Changing the victim's local DNS or hosts file.
- **Fake login pages** - Mimicking banking, email, or corporate websites.
- **SSL certificate abuse** - Using HTTPS or fraudulent certificates to appear legitimate.
- **Silent redirection** - Redirecting users without requiring them to click a malicious link.



Methods - 1 - DNS Poisoning

DNS poisoning is an attack where an attacker manipulates DNS records so that users are

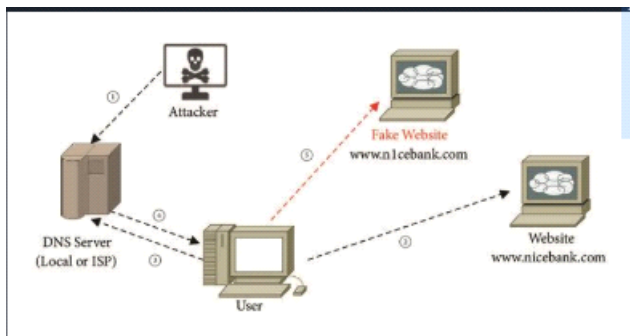
redirected to a fake website instead of the legitimate one.

How it works:

1. The attacker compromises a DNS server or the victim's local router.
2. The user enters a legitimate website address (e.g., www.bank.com).
3. The compromised DNS returns the attacker's IP address instead of the real one.
4. The user is redirected to a fake website without noticing.
5. The attacker steals credentials or other sensitive information.

Key indicator:

Users are silently redirected to a fake website even though they typed the correct URL.



Method - 2 - Hosts File Modification

Hosts file modification is a pharming technique where malware changes the system's hosts file to redirect legitimate websites to a malicious IP address.

How it works:

1. Malware modifies the hosts file on the victim's device.
2. A fake IP address is mapped to a legitimate domain (e.g., www.bank.com).
3. When the user visits the website, the system uses the modified hosts file.
4. The user is redirected to a fake website without realizing it.

5. The attacker steals credentials or sensitive information.

Why Pharming Is Dangerous

- **No suspicious email** - The attack does not rely on phishing emails.
- **No obvious malicious link** - Users type the correct website address.
- **Looks like the real domain** - The fake site closely resembles the legitimate one.
- **Hard to detect** - Redirection happens silently, making the attack difficult for users to notice.

SOC Detection Indicators (Short Description)

- **Sudden DNS record changes** - Unexpected modifications to DNS records that may indicate tampering.
- **Suspicious DNS responses** - DNS queries resolving to unusual or malicious IP addresses.
- **Internal DNS anomalies** - Unusual DNS activity within the organization's network.
- **Multiple users resolving the same domain to an unusual IP** - A sign of possible DNS poisoning or pharming.
- **Hosts file modification alerts** - Detection of unauthorized changes to the system's hosts file.
- **Certificate mismatch errors** - The website's SSL/TLS certificate does not match the expected domain, indicating a possible fake site.

Real SOC Scenario

Alert:

Multiple users accessing **bank.com** are resolving to an unexpected foreign IP address.

Investigation:

1. Review DNS logs for abnormal queries and

- responses.
2. Compare the resolved IP address with the legitimate IP.
 3. Check the DNS server for signs of compromise or unauthorized changes.
 4. Inspect affected endpoints for hosts file modifications or malware.

EVIL TWIN ATTACK

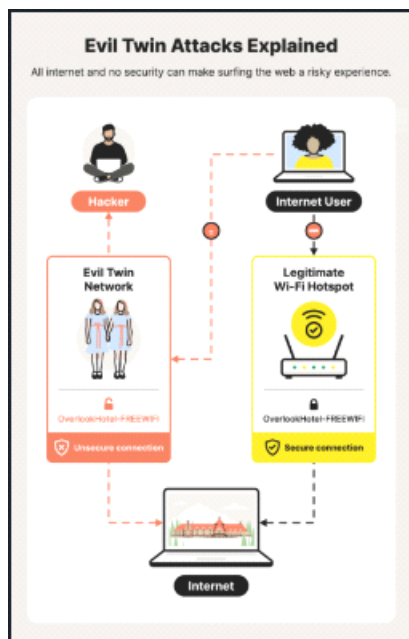
An Evil Twin attack is a wireless attack where an attacker creates a fake Wi-Fi access point that closely resembles a legitimate network to trick users into connecting.

How it works:

1. The attacker sets up a fake Wi-Fi network with a similar name (SSID).
2. The fake network appears to be the legitimate one.
3. Users unknowingly connect to the attacker's access point.
4. The attacker intercepts network traffic or steals login credentials.
5. Sensitive information may be captured or malware may be delivered.

Common tactics:

- **Lookalike Wi-Fi names** - e.g., **Cafe_WiFi** vs. **Cafe_WiFi_Free**.
- **Free public Wi-Fi** - Attracting users with open or unsecured networks.
- **Captive portal phishing** - Displaying a fake login page to steal credentials.
- **Traffic interception** - Monitoring or modifying unencrypted network traffic.
- **Session hijacking** - Stealing session cookies to access user accounts.



This often leads to:

- MITM
- Credential theft
- Cookie stealing
- Fake captive portal login pages

Why it's dangerous:

- **Easy to execute** – Attackers can set up a fake Wi-Fi hotspot with minimal tools.
- **No advanced skills required** – Basic configuration is enough to impersonate a network.
- **Common in public places** – Frequently seen in airports, hotels, cafes, and conferences where users expect open Wi-Fi.
- **User trust exploitation** – People often connect automatically or choose the strongest-sounding network name.

SOC Detection Indicators:

- **Unauthorized access point detected** – Rogue Wi-Fi AP appearing in the corporate environment.
- **Duplicate SSID detected** – Two networks with the same or very similar names.
- **ARP spoofing alerts** – Indicators of traffic interception attempts within the network.

- **Unusual DHCP server detected** - Rogue device assigning IP addresses to clients.
- **Network traffic interception patterns** - Signs of man-in-the-middle activity or abnormal routing behavior.

Enterprise SOC Protections:

- **Wireless IDS (WIDS)** - Monitors and detects rogue or malicious Wi-Fi access points.
- **Network Access Control (NAC)** - Ensures only authorized devices can connect to the network.
- **802.1X authentication** - Uses certificate-based authentication for secure Wi-Fi access.

WHAT IS SOCIAL ENGINEERING?

Social engineering is a cyberattack technique that relies on psychological manipulation to trick people into giving away confidential information or performing actions that compromise security. Instead of exploiting systems, it exploits human behavior.

How it works:

Attackers manipulate trust, fear, urgency, or curiosity to influence victims into:

- Revealing sensitive information (passwords, OTPs, credentials)
- Granting unauthorized access
- Installing malicious software
- Clicking harmful links or attachments
- Transferring money or approving transactions

Key idea:

It targets **people, not technology**—taking advantage of human error rather than system weaknesses.

Core Psychological attacks used by attackers

1. Authority

People obey authority figures

Example: "This is IT dept. , Share your password for system maintenance."

Why it works:

Humans are conditioned to obey authority.

2. Urgency

Removes logical thinking.

Example: "Your account will be deleted in 10 minutes."

Victim panics -> clicks immediately

3. Fear

"income tax notice attached."

Fear disabled rational analysis.

4. Scarcity

"Only 2 bonus slots remaining."

Triggers impulsive decisions.

5. Reciprocity

"I helped you last week, can you send me this document?"

Creates obligation.

6. Familiarity & Trust

Attackers often:

- o Impersonate colleagues
- o Use internal language
- o Reference real projects

TYPES OF SOCIAL ENGINEERING

1. Pretexting

Pretexting is a social engineering technique where an attacker creates a fabricated scenario (a "pretext") to gain a victim's trust and manipulate them into sharing sensitive information or performing actions.

How it works:

1. The attacker researches the target (company, role, processes).
2. They create a believable identity or situation (e.g., IT support, auditor, vendor).
3. The victim is contacted with a convincing story or request.
4. Trust is established through authority or urgency.
5. The victim is tricked into revealing credentials, OTPs, or system access.

Example:

"Hi, I'm from IT support. We are upgrading the VPN system. Please confirm your login credentials so we can migrate your account."

Key point:

Pretexting is **carefully planned and researched**, making it more convincing than generic phishing attacks.



2. Baiting

Baiting is a social engineering attack where the attacker lures victims by offering something attractive or tempting to trigger

curiosity or greed, leading them to compromise their own security.

How it works:

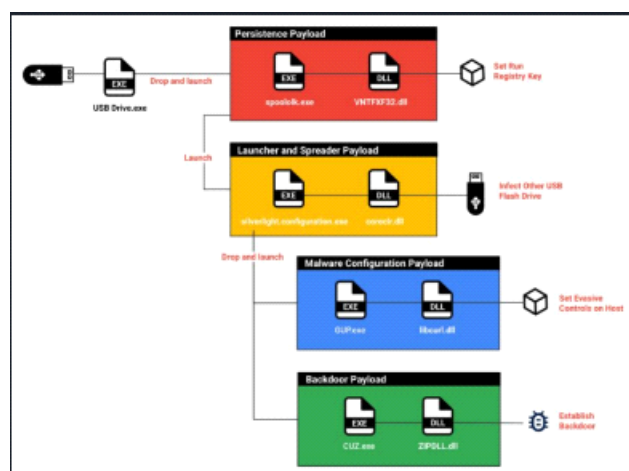
1. The attacker creates an appealing offer (free software, movies, rewards, or sensitive files).
2. The victim is enticed to download a file, click a link, or use a device (like a USB drive).
3. The action installs malware or leads to a malicious website.
4. The attacker gains access to the system or steals data.

Examples:

- Free movie download links that contain malware
- Cracked software bundled with viruses
- USB drive labeled "**Salary Data**" left in public places to tempt users into plugging it in

Key idea:

Baiting works by exploiting **curiosity and greed**, causing users to voluntarily initiate the attack.



3. Watering Hole Attack

A watering hole attack is a targeted cyberattack where attackers compromise a website that is frequently visited by a

specific group of users in order to infect their devices.

How it works:

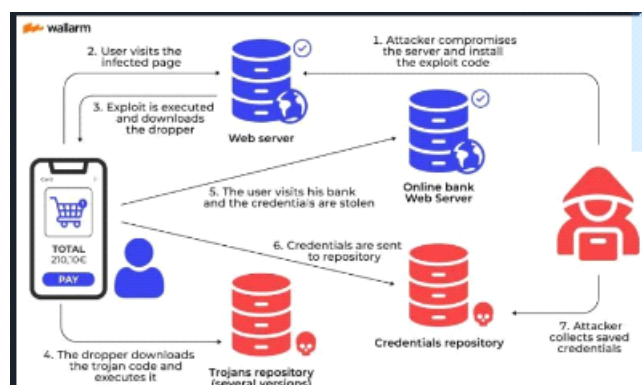
1. The attacker identifies websites commonly used by the target group (e.g., employees of a company or government agency).
2. The attacker compromises one of these trusted websites.
3. Malware or malicious scripts are injected into the site.
4. When users visit the site, their devices get infected automatically or through prompts.
5. The attacker gains access to the victims' systems or networks.

Example:

Government employees regularly visit a specific portal. The attacker compromises that portal and injects malware, so anyone visiting it gets infected.

Key idea:

Watering hole attacks are **highly targeted** and exploit trust in legitimate, frequently used websites.



SOCIAL ENGINEERING LIFECYCLE

1. Reconnaissance

The attacker gathers information about the target using public sources like LinkedIn, company websites, and social media to understand roles, relationships, and internal

processes.

Example: Attacker finds an employee working in finance through LinkedIn.

2. Relationship Building

The attacker builds trust with the victim through emails, calls, or messages by impersonating a trusted person or authority.

Example: Attacker emails the employee pretending to be from the IT support team.

3. Exploitation

Once trust is established, the attacker manipulates the victim into revealing credentials, opening malicious files, or granting access.

Example: Victim shares VPN login details or opens a malicious attachment.

4. Exit

After gaining access or achieving the goal, the attacker removes traces of communication or activity to avoid detection and may proceed with further technical attacks.

Example: Attacker deletes email threads and uses stolen credentials for unauthorized access.

SOC Analyst Perspective (Why each alert matters)

- **Suspicious login after phishing** - Indicates the attacker may have successfully stolen credentials and is testing access to the account.
- **VPN login from new location** - Suggests account compromise or credential misuse from an unusual geographic location.
- **Email forwarding rules created** - Often used by attackers to silently redirect incoming emails for data theft or persistence.
- **MFA reset request** - May indicate an attacker trying to bypass or re-register multi-factor authentication after gaining access.

- **Multiple password reset attempts** - Shows brute-force activity or an attacker trying to take control of the account.
- **Impossible travel login** - A strong sign of compromise where logins occur from locations too far apart in an unrealistic time frame.

SOCIAL ENGINEERING IN INDIAN CONTEXT

Common attacks:

- **Fake GST notices** - Scammers impersonate tax authorities to trick businesses into paying fake penalties or opening malicious attachments.
- **Fake income tax emails** - Fraudulent emails claiming refunds, audits, or penalties to steal credentials or financial data.
- **Fake courier delivery scams** - Messages asking users to reschedule delivery or pay fees via malicious links.
- **KYC verification fraud** - Requests to "update KYC" through fake banking portals to capture login details and identity data.
- **Bank OTP scams** - Attackers trick users into sharing OTPs to complete unauthorized transactions.
- **Fake job offer scams** - Fake recruitment emails asking for documents, registration fees, or personal information.

SOC impact:

- **Credential harvesting** - Users unknowingly submit login details to fake portals.
- **OTP compromise** - Attackers use stolen OTPs for real-time account access.
- **Account takeover** - Full control of email, banking, or corporate accounts after successful deception.

How organizations defend:

- **Security awareness training** - Educating users to identify scams and suspicious

messages.

- **Phishing simulation campaigns** - Testing employee response to fake phishing attempts.
- **Email filtering** - Blocking malicious or spoofed emails before they reach users.
- **MFA enforcement** - Adding extra authentication layers to reduce account compromise risk.
- **Domain monitoring** - Detecting fake or lookalike domains used for attacks.
- **Zero Trust approach** - Verifying every request regardless of source before granting access.

PASSWORD & CREDENTIAL STUFFING ATTACK

02 July 2026 16:20

TYPES OF PASSWORD ATTACKS

Brute Force Attack

A **Brute Force Attack** is a type of cyberattack in which an attacker repeatedly tries different password combinations until the correct one is found. Instead of exploiting a software vulnerability, the attacker relies on trial and error to gain unauthorized access to an account or system.

Simple Workflow:

Try → Fail → Try → Fail → Try → Success

How It Works

A brute force attack typically follows these steps:

1. The attacker identifies a target login portal (e.g., VPN, RDP, web application, email, or SSH).
2. Automated tools send thousands or even millions of password attempts.
3. Each attempt is checked against the authentication system.
4. If there is no account lockout, CAPTCHA, or rate limiting, the attacker continues until the correct password is found.
5. Once successful, the attacker gains unauthorized access.

Example Flow:

- Target: VPN Login
- Username: administrator
- Password Attempts:
 - admin123 ✕
 - password123 ✕
 - Welcome@123 ✕

o Admin@2025 ☒

SOC Indicators

A Security Operations Center (SOC) analyst can identify brute force attacks by monitoring authentication logs and network activity.

Windows Event Logs

- **Event ID 4625** - Failed login attempts
- Multiple failed logins from the same IP address
- Repeated login attempts against the same username
- Large number of authentication failures within a short period
- Event ID **4624** (Successful login) immediately after many failed attempts

Firewall / VPN / Authentication Logs

- High number of authentication failures
- Login attempts occurring at a very high frequency
- Repeated login requests from a single external IP
- Multiple usernames being targeted from one source (password spraying)
- Unusual login activity outside normal business hours

Real-Life Example

A SOC analyst notices the following activity:

- **User:** administrator
- **Failed Login Attempts:** 500
- **Source IP:** 185.x.x.x
- **Time Window:** 10 minutes
- **Windows Log:** Event ID **4625** repeated hundreds of times

Analysis

This pattern strongly indicates a **Brute Force Attack** because:

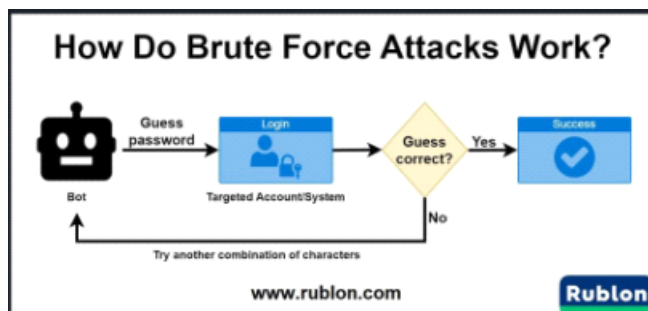
- A large number of failed login attempts occurred.
- The same account was targeted repeatedly.
- All attempts originated from a single external IP address.
- The login frequency is much higher than normal user behavior.

If a successful login (**Event ID 4624**) follows these failures, it may indicate that the attacker successfully guessed the password.

Prevention

Organizations can reduce the risk of brute force attacks by implementing:

- Strong, complex passwords
- Multi-Factor Authentication (MFA)
- Account lockout after multiple failed attempts
- Rate limiting on login requests
- CAPTCHA on authentication pages
- Monitoring and alerting for excessive failed logins
- Blocking suspicious IP addresses using firewalls or intrusion prevention systems

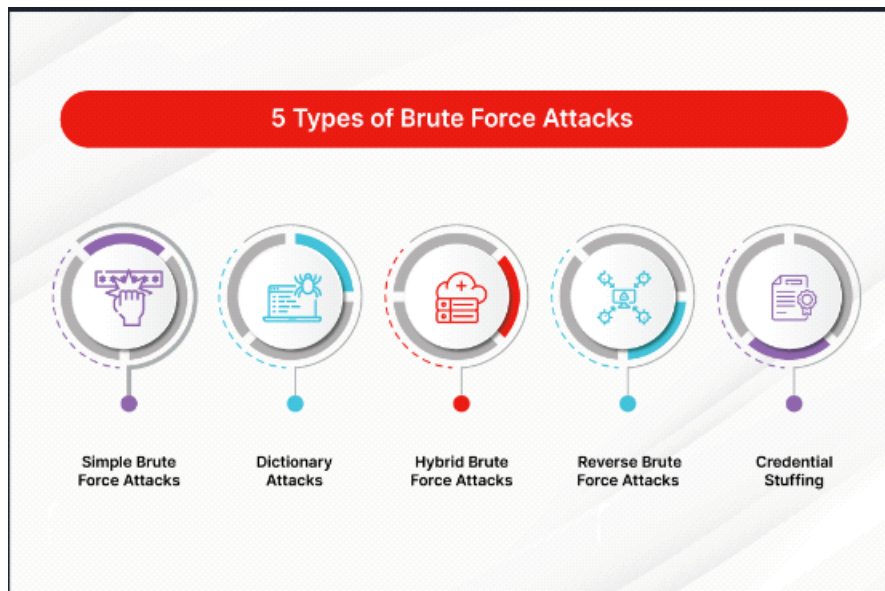


Types Of Brute Force Attacks

Uses Automated tools:

- Hydra
- Burp Suite
- Medusa

- Ncrack



Reverse Brute Force Attack

A **Reverse Brute Force Attack** is a password-based attack where the attacker uses **one common or likely password** against **many different user accounts** until a match is found.

Unlike a traditional brute force attack, which tries **many passwords for one user**, a reverse brute force attack tries **one password for many users**. Attackers often choose passwords they believe are commonly used within an organization, such as **Summer2025**, **Welcome@123**, or **Company@123**.

Traditional Brute Force: Many passwords → One user

Reverse Brute Force: One password → Many users

How It Works

A reverse brute force attack typically follows these steps:

1. The attacker obtains or guesses a list of valid usernames (from public sources, email addresses, or previous data breaches).

2. The attacker selects a common or predictable password.
3. The same password is attempted against every account on the list.
4. If the password matches any account, the attacker gains unauthorized access.
5. The attacker may repeat the process with another commonly used password if needed.

Example Flow:

- Password Used: Summer2025
- Login Attempts:
 - alice → ✗
 - bob → ✗
 - charlie → ✗
 - david → ☒

SOC Indicators

A Security Operations Center (SOC) analyst can identify reverse brute force attacks by looking for authentication patterns across multiple accounts.

Windows Event Logs

- **Event ID 4625** (Failed Login) generated for many different usernames.
- The same source IP attempting logins for multiple accounts.
- Authentication failures spread across numerous user accounts within a short time.
- A successful **Event ID 4624** after multiple failed attempts using the same source IP.

Firewall / VPN / Authentication Logs

- One external IP attempting to authenticate to many different user accounts.
- High number of authentication failures using different usernames.
- Login attempts occurring at a consistent or automated rate.

- Multiple failed logins followed by one successful login from the same IP.
- Authentication attempts outside normal business hours or from unusual locations.

Example

A SOC analyst observes:

- **Source IP:** 185.x.x.x
- **Password Used:** Summer2025
- **Usernames Targeted:** 300 different accounts
- **Time Window:** 15 minutes
- **Windows Logs:** Hundreds of **Event ID 4625** entries across different users

Analysis

This activity is characteristic of a **Reverse Brute Force Attack** because:

- One password is being tried against many user accounts.
- Multiple authentication failures are occurring from the same source IP.
- The attack targets numerous users instead of repeatedly targeting a single account.
- If one account eventually generates **Event ID 4624** (Successful Login), it may indicate the attacker found a user with that password.

Dictionary Attack

A **Dictionary Attack** is a password attack in which an attacker attempts to gain unauthorized access by trying passwords from a **predefined list (dictionary)** of commonly used passwords, leaked passwords, and predictable word combinations.

Unlike a brute force attack, which tries every possible password combination, a dictionary attack only tests passwords that are likely to be used by real users, making it faster and more efficient.

Brute Force: Tries every possible password combination.

Dictionary Attack: Tries passwords from a predefined wordlist.

How It Works

A dictionary attack typically follows these steps:

1. The attacker identifies a target login portal (VPN, RDP, web application, email, SSH, etc.).
2. The attacker obtains or creates a dictionary (wordlist) containing common passwords such as:
 - o password123
 - o Welcome@123
 - o Summer2025
 - o Admin@123
3. Automated tools try each password from the dictionary against the target account(s).
4. If a password matches, the attacker gains unauthorized access.
5. If no password works, the attacker may switch to another wordlist or use a different attack method.

Example Flow:

- Target User: administrator
- Password Attempts:
 - o 123456 ✗
 - o password123 ✗
 - o Welcome@123 ✗
 - o Admin@2025 ✓

SOC Indicators

A Security Operations Center (SOC) analyst can detect dictionary attacks by monitoring authentication logs for repeated login failures using common password patterns.

Windows Event Logs

- **Event ID 4625** - Multiple failed login attempts.

- Repeated authentication failures for the same user or multiple users.
- Login attempts from the same source IP using common password guesses.
- **Event ID 4624** (Successful Login) immediately after several failed attempts.

Firewall / VPN / Authentication Logs

- High number of authentication failures from a single IP.
- Login attempts occurring at a steady, automated rate.
- Multiple accounts being targeted using common passwords.
- Authentication activity outside normal business hours.
- A successful login after numerous failed password attempts.

Real-Life Example

A SOC analyst observes:

- **Target User:** administrator
- **Source IP:** 185.x.x.x
- **Failed Login Attempts:** 150
- **Time Window:** 8 minutes
- Passwords attempted include:
 - password123
 - Welcome@123
 - Admin123
 - Summer2025

Analysis

This activity is characteristic of a

Dictionary Attack because:

- The attacker is trying passwords from a predefined list of common passwords.
- Numerous failed authentication attempts are occurring in a short period.
- The same source IP is repeatedly attempting to log in.
- If a **Windows Event ID 4624** (Successful Login) appears after these failures, it may

indicate that one of the dictionary passwords was correct.

Password Spraying

A **Password Spraying Attack** is a password attack in which an attacker tries **a small number of common passwords** against **many different user accounts** instead of trying many passwords against a single account.

The goal is to avoid account lockout policies by making only one or a few login attempts per user while identifying accounts that use weak or common passwords.

Traditional Brute Force: Many passwords →
One user

Password Spraying: Few common passwords →
Many users

How It Works

A password spraying attack typically follows these steps:

1. The attacker obtains a list of valid usernames (e.g., from public websites, email directories, or previous data breaches).
2. The attacker selects a common password such as:
 - o Spring2026!
 - o Welcome@123
 - o Password1
3. The same password is tried against every account on the list.
4. After completing one round, the attacker waits to avoid account lockouts.
5. The attacker repeats the process with another common password until a valid login is found.

Example Flow:

Password: Welcome@123

- alice → **X**
- bob → **X**

- charlie → ☒
- david → ✗
- emma → ✗

After some time:

Password: Spring2026!

- alice → ✗
- bob → ☒
- charlie → (Skipped - already compromised)
- david → ✗

SOC Indicators

A Security Operations Center (SOC) analyst can identify password spraying by looking for authentication failures spread across many user accounts using the same source IP.

Windows Event Logs

- **Event ID 4625** - Failed login attempts across many different usernames.
- Authentication failures for multiple users from the same IP address.
- Only one or two failed attempts per account, making account lockouts less likely.
- **Event ID 4624** (Successful Login) after widespread failed attempts.

Firewall / VPN / Authentication Logs

- One external IP attempting logins for many different user accounts.
- Low number of attempts per account but a high number of accounts targeted.
- Authentication attempts spread over minutes or hours to avoid detection.
- Login attempts outside normal business hours or from unusual geographic locations.
- One or more successful logins following widespread authentication failures.

Real-Life Example

A SOC analyst observes:

- **Source IP:** 185.x.x.x

- **Password Attempted:** Welcome@123
- **User Accounts Targeted:** 400
- **Failed Logins:** 399
- **Successful Login:** 1
- **Time Window:** 2 hours

Analysis

This activity is characteristic of a **Password Spraying Attack** because:

- The same common password is being tried against many different user accounts.
- Each account receives only one or a few login attempts.
- The attacker is attempting to bypass account lockout policies.
- A successful **Event ID 4624** after many **Event ID 4625** events may indicate that one account used the common password.

Hybrid Attack

A **Hybrid Password Attack** is a password attack that combines a **dictionary attack** with **password variations** to increase the chances of successfully guessing a user's password. Instead of trying only common dictionary words, the attacker modifies them by adding numbers, years, symbols, company names, or other predictable patterns. Hybrid attacks are often **customized to target a specific organization**, making them more effective than standard dictionary attacks.

Dictionary Attack: Uses passwords exactly as they appear in a wordlist.

Hybrid Attack: Uses dictionary words with predictable variations.

How It Works

A hybrid attack typically follows these steps:

1. The attacker identifies the target organization or user.

2. The attacker collects common passwords or dictionary words.
3. The attacker generates password variations by adding:
 - o Years (2024, 2025, 2026)
 - o Numbers (123, 1234)
 - o Symbols (@, !, #)
 - o Company name
 - o Seasonal words (Summer, Winter)
4. Automated tools attempt these customized passwords against the target account(s).
5. If one variation matches, the attacker gains unauthorized access.

Example Flow:

Dictionary Word: Company

Generated Passwords:

- Company123
- Company@123
- Company2026
- Company@2026
- Company!

Eventually:

- Company@2026 ☒

SOC Indicators

A Security Operations Center (SOC) analyst can detect hybrid attacks by identifying repeated login attempts using predictable password variations.

Windows Event Logs

- **Event ID 4625** - Multiple failed login attempts.
- Repeated authentication failures against one or more accounts.
- Password attempts following similar naming patterns.
- **Event ID 4624** (Successful Login) after several failed attempts.

Firewall / VPN / Authentication Logs

- Multiple authentication failures from the same IP address.

- Login attempts using slight password variations.
- Passwords customized with:
 - Company name
 - Current year
 - Common numbers (123, 1234)
 - Symbols (@, !)
- Repeated login attempts at an automated rate.

Real-Life Example

A SOC analyst observes:

- **Target User:** administrator
- **Source IP:** 185.x.x.x
- **Failed Login Attempts:** 120
- **Time Window:** 10 minutes

Password attempts include:

- Company@2023
- Company@2024
- Company@2025
- Company@123
- Company123

Analysis

This activity is characteristic of a **Hybrid Password Attack** because:

- The attacker is using a common base word (Company) with predictable variations.
- The passwords are customized to the target organization.
- Multiple authentication failures originate from the same IP address.
- If a **Windows Event ID 4624** (Successful Login) follows these failures, it may indicate one of the password variations was correct.

Rainbow Table Attack

A **Rainbow Table Attack** is a password-cracking technique in which an attacker uses

precomputed tables of password hashes to recover the original plaintext passwords from stolen password hashes.

Instead of guessing passwords one by one, the attacker compares the stolen hash against a large database of previously computed hashes. If a matching hash is found, the corresponding plaintext password is revealed almost instantly.

Hash: 5f4dcc3b5aa765d61d8327deb882cf99

Recovered Password: password

How It Works

A rainbow table attack typically follows these steps:

1. The attacker compromises a system and steals a database containing password hashes (e.g., **MD5, SHA-1**).
2. The attacker obtains a precomputed rainbow table containing millions of password-hash pairs.
3. Each stolen hash is compared against the rainbow table.
4. If a matching hash is found, the corresponding plaintext password is recovered.
5. The recovered password can then be used to access user accounts or other systems where the same password is reused.

Example Flow:

- Stolen Hash:
5f4dcc3b5aa765d61d8327deb882cf99
- Rainbow Table Lookup
- Matching Password: password

SOC Indicators

Unlike online password attacks, a **Rainbow Table Attack** is performed **offline** after password hashes have been stolen. Therefore, SOC analysts typically **cannot directly observe** the attack in authentication logs.

Windows Event Logs

- No **Event ID 4625** (Failed Login) related to the hash cracking process.
- No unusual authentication activity while the hashes are being cracked.

SOC / DFIR Indicators

- Detection of a database theft containing password hashes.
- Evidence of credential dumping or database exfiltration.
- Large outbound data transfers from database servers.
- Signs that weak or unsalted password hashes (e.g., MD5, SHA-1) were exposed.
- During a **Digital Forensics and Incident Response (DFIR)** investigation, recovered passwords may indicate that rainbow tables were used.

Note: SOC teams usually detect the **data breach or credential theft**, while the **offline hash cracking** is often identified later during a DFIR investigation.

Real-Life Example

A company experiences a database breach. The attacker steals a database containing:

- Usernames
- Password hashes (MD5)

Example hash:

- 5f4dcc3b5aa765d61d8327deb882cf99

The attacker searches a rainbow table and finds that the hash corresponds to:

- password

Analysis

This is a **Rainbow Table Attack** because:

- The attacker is not guessing passwords through the login page.
- Stolen password hashes are being matched against a precomputed lookup table.
- No authentication failures are generated during the password-cracking process.
- If the recovered passwords are later used to

log in, the SOC may then observe successful or suspicious authentication events.

Credential Stuffing

A **Credential Stuffing Attack** is an account takeover attack in which an attacker uses **previously leaked username and password combinations** from data breaches to gain unauthorized access to other accounts. The attack relies on **password reuse**. If a user uses the same password across multiple websites or services, credentials leaked from one breach may work on other platforms.

Credential Stuffing: Stolen username/password pairs → Multiple websites and services

How It Works

A credential stuffing attack typically follows these steps:

1. The attacker obtains username and password combinations from previous data breaches.
2. The attacker uses automated tools to test these credentials against different login portals, such as:
 - o Email services
 - o Banking applications
 - o VPNs
 - o Corporate portals
 - o Cloud services
3. If users have reused the same password, the login succeeds.
4. The attacker gains unauthorized access and may steal data, move laterally, or escalate privileges.

Example Flow:

Stolen Credentials:

- Username: john@example.com
- Password: Welcome@123

The attacker tests the same credentials on:

- Email → ☒

- VPN → ✗
- Corporate Portal → ☒
- Banking Website → ✗

SOC Indicators

A Security Operations Center (SOC) analyst can identify credential stuffing by monitoring authentication logs for unusual login behavior and signs of account takeover.

Windows Event Logs

- **Event ID 4624** - Successful logins from unusual locations or devices.
- **Event ID 4625** - Failed login attempts before successful authentication.
- Multiple login attempts using valid usernames.
- Successful authentication after numerous failed login attempts.

Firewall / VPN / Authentication Logs

- Login attempts from multiple IP addresses.
- Successful logins from unusual geographic locations.
- **Impossible travel** alerts (e.g., login from India followed by another login from Germany within minutes).
- High login success rate after many failed attempts.
- Multiple user accounts accessed from the same IP using valid credentials.
- Unusual login times or access from previously unseen devices.

Real-Life Example

A company notices the following activity:

- **Username:** employee@company.com
- **Source IPs:** Multiple IP addresses from different countries
- **Authentication Events:**
 - Several failed login attempts
 - Followed by a successful login

- The successful login originates from a country the employee has never accessed from.

Investigation reveals that the employee's credentials were exposed in a previous third-party website breach and the same password was reused for the corporate VPN.

Analysis

This is a **Credential Stuffing Attack** because:

- The attacker is using previously leaked username/password pairs.
- The credentials are valid, so the login succeeds without guessing the password.
- Login attempts originate from unusual locations or multiple IP addresses.
- Security systems may generate **Impossible Travel** or **Anomalous Login** alerts.

MFA Fatigue Attack

An **MFA Fatigue Attack** (also called a **Push Fatigue Attack** or **MFA Prompt Bombing**) is a social engineering attack in which an attacker repeatedly triggers Multi-Factor Authentication (MFA) requests until the user approves one of them.

The attacker typically already has the victim's **username and password**. Instead of bypassing MFA technically, they rely on the victim approving a login request out of confusion, annoyance, or frustration.

Attacker has the password → Sends repeated MFA prompts → User accidentally approves → Unauthorized access

How It Works

An MFA fatigue attack typically follows these steps:

1. The attacker obtains the victim's username and password (often through phishing or credential stuffing).

2. The attacker attempts to log in to an MFA-protected account.
3. Each login attempt generates an MFA push notification on the victim's device.
4. The attacker repeatedly sends MFA requests over a short period.
5. The victim eventually clicks **"Approve"**, believing the prompts are legitimate or simply to stop the notifications.
6. The attacker successfully logs in and gains unauthorized access.

Example Flow:

- Attacker logs in using stolen credentials.
- Victim receives multiple MFA notifications.
- Victim ignores the first few requests.
- After repeated prompts, the victim taps **Approve**.
- Login succeeds. ☒

SOC Indicators

A Security Operations Center (SOC) analyst can detect MFA fatigue attacks by monitoring authentication and MFA logs.

Identity Provider / Authentication Logs

- Multiple MFA push notifications sent to the same user within a short period.
- Several denied or ignored MFA requests followed by an approved request.
- Successful login immediately after repeated MFA prompts.
- Authentication attempts from unfamiliar IP addresses, devices, or locations.

Windows / Cloud Authentication Logs

- **Event ID 4624** (Successful Login) following repeated authentication attempts.
- Multiple failed or interrupted login attempts before a successful authentication.
- New device or browser used for the successful login.

Common SIEM Alerts

- Excessive MFA challenges for a single

account.

- Multiple authentication attempts from the same external IP.
- Impossible travel or impossible location alerts.
- Login from a device never previously used by the user.
- High-risk sign-in detected after MFA approval.

Real-Life Example

A SOC analyst observes:

- **User:** employee@company.com
- **MFA Push Notifications:** 25
- **Time Window:** 15 minutes
- **Authentication Attempts:** Multiple failed logins
- **Final Event:** MFA approved and login successful
- **Source IP:** External IP from another country

Analysis

This activity is characteristic of an **MFA Fatigue Attack** because:

- The attacker already possessed the correct username and password.
- Multiple MFA requests were generated in a short period.
- The user eventually approved one of the requests.
- The successful login originated from an unusual location, indicating possible account compromise.

Where These Attacks Commonly Target

Target Why Attackers Target It

RDP	Remote Desktop Protocol (RDP) provides
(Port 3389)	remote access to Windows systems. A successful login gives the attacker

interactive control of the machine, allowing them to execute commands, install malware, or move laterally within the network.

SSH (Port 22) **Secure Shell (SSH)** is used to remotely manage Linux, Unix, and network devices. A compromised SSH account can provide command-line access to servers and infrastructure.

VPN Portals A **Virtual Private Network (VPN)** grants users remote access to an organization's internal network. If an attacker logs in successfully, they may appear as a legitimate remote employee and gain access to internal resources.

Web Applications Web applications (such as email portals, CRM systems, HR portals, and cloud applications) often contain sensitive business data. Weak or reused passwords can allow attackers to compromise user accounts and steal information.

Database Login Panels Databases store valuable information such as customer records, financial data, and intellectual property. If an attacker obtains valid database credentials, they may be able to view, modify, or exfiltrate sensitive data.

Real-World Attack Chain Example (Common in Ransomware Incidents)

Imagine a company named **ABC Manufacturing**.

Step 1: Phishing Email

An employee receives an email that appears to come from the company's IT department.

Subject: *VPN Password Expiration Notice*

The email asks the employee to log in using a provided link to update their password.

The employee clicks the link and unknowingly enters their username and password into a fake login page.

Result: The attacker steals the employee's credentials.

Step 2: Attacker Attempts VPN Login

Using the stolen credentials, the attacker tries to log in to the company's VPN.

However, the VPN requires **Multi-Factor Authentication (MFA)**.

The attacker knows the password but cannot complete the MFA challenge.

Result: Initial access attempt fails.

Step 3: Password Spraying Attack

Instead of giving up, the attacker launches a **password spraying attack** against other accounts in the organization.

The attacker tries a common password such as:

- Welcome@123

against hundreds of employee and service accounts.

Most accounts fail, but one **legacy service account** is still using the weak password.

Result: The attacker successfully authenticates using the service account.

Step 4: Internal Access

Because the compromised service account has VPN access, the attacker enters the company's internal network.

Once inside, the attacker:

- Enumerates systems and users.
- Scans the network for file servers and domain controllers.
- Steals additional credentials.
- Moves laterally to other systems.
- Escalates privileges to gain administrative access.

Step 5: Ransomware Deployment

After gaining sufficient privileges, the attacker:

- Disables security tools where possible.
- Exfiltrates sensitive company data.
- Deploys ransomware across multiple systems.
- Encrypts servers and workstations.
- Leaves a ransom note demanding payment to restore access.

The company experiences significant operational disruption and potential data loss.

SOC Perspective

During the investigation, the SOC team may observe:

- Phishing email delivered to the employee.
- Successful login from an unusual IP address or location.
- Multiple failed VPN authentication attempts.
- Password spraying activity targeting many accounts.
- Successful login to a service account with a weak password.
- Lateral movement using remote administration tools (e.g., RDP, SMB, PsExec).
- Creation of new privileged accounts or privilege escalation.
- Large volumes of data transferred outside the network.
- Ransomware execution and widespread file encryption alerts.

SOC L1 Investigation Workflow

1. Source IP

This tells you **who is generating the traffic.**

- Same IP → likely automated attack (brute force / spraying tool)
- Many IPs → botnet, distributed attack, or credential stuffing infrastructure
- Known bad IP → higher confidence threat

👉 Helps answer: *Is it one attacker or many?*

2. Geolocation

This shows **where the login attempts are coming from**.

- Unexpected country → suspicious or impossible for user
- Matches user location → lower suspicion
- Rapid location change → possible compromise or VPN abuse

👉 Helps answer: *Does this look like the real user?*

3. Username Targeted

This shows **what is being attacked**.

- One user → brute force or targeted attack
- Many users → password spraying or credential stuffing
- Admin/service accounts → high-risk targeting

👉 Helps answer: *Who is the attacker focusing on?*

4. Success or Only Failures?

This is the **most critical decision point**.

- Only failures → scanning or blocked attack
- One success after failures → likely compromise
- Multiple successes → credential stuffing or widespread breach

👉 Helps answer: *Did the attacker get in?*

5. Time Frequency

This shows **attack behavior pattern**.

- Very fast attempts → automated brute force tool
- Slow, spaced attempts → password spraying (avoid lockout)
- Bursty patterns → scripted credential stuffing

👉 Helps answer: *What type of attack is this?*

6. Account Lockout Triggered?

This tells you **defensive system response + attack intensity**.

- Lockouts happening → attack is hitting same user repeatedly (brute force)
- No lockouts → spraying or distributed attack
- Many lockouts → potential service disruption risk

🔑 Helps answer: *Is the attack being contained or still effective?*

7. Any Successful Login After Failures?

This is the **highest priority SOC check**.

- Failures only → noise or blocked attempt
- Success after failures → **possible credential compromise**
- Success from unusual IP/device → strong indicator of breach

🔑 Helps answer: *Is this an incident or just an attempt?*

Why These Specifically?

Because together they cover the **core SOC triage questions**:

1. **Who is attacking?** → Source IP
2. **Where from?** → Geo location
3. **Who is targeted?** → Username
4. **What is the outcome?** → Success vs failure
5. **How is it happening?** → Time frequency
6. **Is defense working?** → Lockouts
7. **Is compromise confirmed?** → Successful login

Important Logs to Master



Windows Logs

Event ID 4625 → Failed Login

This is one of the most important security events.

What it means:

A login attempt failed due to wrong password, unknown username, or account restrictions.

Why it matters:

- Indicates brute force or password spraying
- Helps identify targeted accounts
- Shows attack patterns (frequency, IP, username)

SOC use cases:

- Detect repeated failed logins from same IP
- Identify credential stuffing attempts
- Monitor admin account targeting

Event ID 4624 → Successful Login

This shows a successful authentication.

What it means:

A user successfully logged into the system.

Why it matters:

- Confirms access (legitimate or malicious)
- Used to correlate with failed login attempts
- Critical for detecting account takeover

SOC use cases:

- Successful login after many 4625 failures → possible compromise
- Login from unusual IP or location → suspicious activity
- New device login → potential credential theft

Event ID 4776 → NTLM Authentication

This logs NTLM-based authentication attempts.

What it means:

Windows is validating credentials using NTLM protocol (common in legacy systems).

Why it matters:

- NTLM is often targeted in **pass-the-hash attacks**
- Weak authentication protocol compared to Kerberos
- Frequently abused in lateral movement

SOC use cases:

- Detect repeated NTLM failures (brute force)
- Identify legacy authentication usage
- Monitor for abnormal domain authentication patterns

Event ID 4740 → Account Lockout

This occurs when an account is locked after too many failed login attempts.

What it means:

User account is temporarily disabled due to security policy.

Why it matters:

- Strong indicator of brute force or password spraying
- Helps identify targeted accounts
- Shows attack intensity

SOC use cases:

- Identify which accounts are under attack
- Correlate lockouts with source IP
- Detect password spraying campaigns



Linux Logs

/var/log/auth.log

This is the primary authentication log on Linux systems.

What it contains:

- SSH login attempts
- sudo usage
- Authentication failures
- Root login attempts

Why it matters:

- Core log for Linux security monitoring
- Shows both successful and failed access attempts

SOC use cases:

- Detect SSH brute force attacks
- Monitor root login attempts
- Identify unauthorized sudo usage

SSH Login Attempts

Logged within auth logs or secure logs.

What it shows:

- Remote login attempts via SSH (Port 22)
- Username and IP address of attacker
- Success or failure of login

SOC use cases:

- Detect brute force on SSH
- Identify credential stuffing on Linux servers
- Monitor for unusual geographic access

Firewall Logs

Repeated Connection Attempts

These logs show network-level activity.

What it means:

Multiple attempts to connect to a service or port.

Why it matters:

- Indicates scanning or brute force activity
- Helps detect attack before login even happens

SOC use cases:

- Port scanning detection
- RDP/SSH/VPN brute force attempts
- Early warning before authentication logs show activity

Blocked Connection Spikes

This shows firewall is actively blocking traffic.

What it means:

Large number of blocked requests from a source IP or range.

Why it matters:

- Confirms malicious or unwanted traffic
- Shows attack intensity and persistence

SOC use cases:

- Detect botnet activity
- Identify distributed brute force attacks
- Measure attack scale over time

Prevention Mechanism

How These Security Controls Prevent Password Attacks

Account Lockout Policy

What it does:

Locks a user account after a set number of failed login attempts.

How it prevents attacks:

- Stops **brute force attacks** (many attempts on one user)
- Makes repeated guessing impossible after threshold

Limits:

- Less effective against **password spraying** (few attempts per user)

MFA Enforcement

What it does:

Requires a second factor (OTP, push, token, biometric).

How it prevents attacks:

- Blocks login even if password is stolen
- Stops **credential stuffing, brute force success, and hybrid attacks**

Important note:

- Push-based MFA can be vulnerable to **MFA fatigue attacks**
- Strong MFA (FIDO2/passkeys) is phishing-resistant

Rate Limiting

What it does:

Slows down login attempts from an IP or user.

How it prevents attacks:

- Makes brute force **too slow to be practical**
- Disrupts automated tools used in spraying and credential stuffing

Key effect:

Turns a high-speed attack into a time-consuming, detectable one

** CAPTCHA****What it does:**

Blocks automated bots after suspicious behavior.

How it prevents attacks:

- Stops scripted login attempts
- Forces human interaction

Limits:

- Advanced bots can bypass weak CAPTCHAs
- Not effective against targeted manual attacks

** Geo-Blocking****What it does:**

Restricts logins based on geographic location.

How it prevents attacks:

- Blocks access from high-risk countries
- Reduces exposure to global brute force bots

SOC benefit:

- Helps detect **impossible travel scenarios**

** Strong Password Policy****What it does:**

Enforces complex and unique passwords.

How it prevents attacks:

- Breaks **dictionary attacks**
- Reduces success of **password spraying**
- Makes hybrid attacks harder

Key point:

Strength + uniqueness is what kills most password-based attacks

** Disable Default Accounts****What it does:**

Removes or renames built-in accounts like:

- admin

- root
- administrator

How it prevents attacks:

- Attackers often target known default usernames
- Stops automated scanning for common accounts

Example:

If admin/admin exists → easy target

If renamed/disabled → attack fails early

Attack Comparison

Attack	Speed	Detection Difficulty	Common in SOC
Brute Force	High	Easy	Very Common
Dictionary	Medium	Medium	Common
Password Spraying	Low & Slow	Hard	Very Common
Credential Stuffing	Medium	Hard	Very Common
Hybrid	Medium	Medium	Common
Rainbow Table	Offline	Hard	Post-breach
MFA Fatigue	Stealthy	Hard	Increasing

HASHING , SALTING & ENCRYPTION

02 July 2026 16:20